INSTITUTO A VOZ DO MESTRE
PROGRAMA DE PÓS-GRADUAÇÃO EM
SEGURANÇA DE REDES DE COMPUTADORES

FRANCISCO RICARDO ANDRASCHKO

A SEGURANÇA EM REDES DE COMUNICAÇÃO PARA SISTEMAS DE AUTOMAÇÃO INDUSTRIAL – BREVE ESTUDO

SÃO JOSÉ DO RIO PRETO/SP
2014

FRANCISCO RICARDO ANDRASCHKO

A SEGURANÇA EM REDES DE COMUNICAÇÃO PARA SISTEMAS DE AUTOMAÇÃO INDUSTRIAL – BREVE ESTUDO

Monografia apresentada ao Instituto A Voz do Mestre, como requisito parcial para a obtenção do título de Especialista em Segurança de Redes de Computadores.

Orientador: Prof. Ludmilla Flôres Meneses Lima

SÃO JOSÉ DO RIO PRETO/SP

2014

INSTITUTO A VOZ DO MESTRE
PROGRAMA DE PÓS-GRADUAÇÃO EM
SEGURANÇA DE REDES DE COMPUTADORES

FRANCISCO RICARDO ANDRASCHKO

A SEGURANÇA EM REDES DE COMUNICAÇÃO PARA SISTEMAS DE AUTOMAÇÃO INDUSTRIAL – BREVE ESTUDO

APROVADO EM ____/____/____

BANCA EXAMINADORA

_____

LUDMILLA FLÔRES MENESES LIMA – ORIENTADOR E PRESIDENTE DA BANCA

_____

NOME DO PROFESSOR – EXAMINADOR

_____

NOME DO PROFESSOR – EXAMINADOR

DEDICATÓRIA

Dedico este trabalho as duas grandes importâncias da minha vida, minha esposa Michele Andraschko e bebê Lua, nossa gata siamesa, que por várias noites aturaram luzes acessas e comentários técnicos.

AGRADECIMENTOS

Agradeço a minha esposa por estar ao meu lado em mais essa jornada. Como cita o Ditado Popular: Por trás de um grande homem, existe uma grande mulher. E complemento dizendo que com certeza a minha é a maior de todas!

Agradeço também a todos que contribuíram respondendo o questionário online, pois apesar de rápido, sempre se torna maçante esse tipo de atividade.

A vingança nunca é plena, mata a Alma e a Envenena.

Seu Madruga (Personagem de Don Ramón)

RESUMO

À alguns anos Tecnologia da Informação deixou de ser sinônimo de um computador e algumas planilhas eletrônicas ou editores de texto, passando a ser uma trama de aplicativos, redes de comunicações e acima de tudo um parceiro dos negócios, ou seja, deixou de ser uma mera ferramenta para tornar-se um apoio a tomadas de decisões, um parceiro no avanço tecnológico industrial e comercial, cada vez mais engajado com as metas e objetivos da empresa e agindo ativamente nas decisões e resultados. Com isso redes de comunicações para sistemas industriais passaram a apresentar e requerer níveis de seguranças melhorados, mais abrangentes e elaborados, afim de que pragas virtuais (principalmente) de diferentes tipos não comprometam o alinhamento entre a TI e o Negócio.

Objetivando um apoio a esta problemática, este trabalho apresenta um breve estudo sobre as vertentes das redes de comunicações industriais, as principais vulnerabilidades e/ou malwares que podem atingir os sistemas de Automação industrias (e as redes componentes destes sistemas) e um plano de ação e continuidade às redes de comunicações industriais.

Palavras-chave: rede de comunicação industrial; segurança da informação; plano de ação e continuidade às redes industriais.

ABSTRACT

For years the Information Technology is no longer synonymous with a computer and few spreadsheets or writers, becoming a lot of applications and communications network and foremost a business partner, ceased to be a mere tools to become a support for decision making, a partner in the technological industrial and commercial breakthrough, becoming more engaged with the goals and objectives of the company and acting actively in decisions and results. With the communications network for industrial systems now present and required enhanced levels of security, more comprehensive and elaborate, so that malware (mostly) of different types do not compromise the alignment between IT and Business.

Aiming to support this issue, this paper presents a short study on aspects of industrial communications networks, the main vulnerabilities and/or malware to can achieve the Industrial Automation Systems (and components of these systems networks) and an action plan and continuity the industrials communications networks.

Key-words: industrial communications network; security of information; action plan and continuity the industrials communications networks.

LISTA DE ILUSTRAÇÕES

FIGURA 1 - ARRANJO DE PROTOCOLOS NAS CAMADAS. FONTE: (ARAUJO, 2011) 15
FIGURA 2 - COMPARATIVO DAS CAMADAS OSI E CAMADAS TCP/IP. FONTE: (TORRES, 2007) 15
FIGURA 3 - CAMADAS OSI. FONTE: (SOUZA, 2012) 16
FIGURA 4 - EXEMPLO DE REDE DE ÁREA LOCAL (LAN) 19
FIGURA 5 - EXEMPLO DE REDE DE ÁREA LOCAL SEM FIO (WLAN) 19
FIGURA 6 - EXEMPLO DE REDE DE LONGA DISTÂNCIA (WAN) 20
FIGURA 7 - EXEMPLO DE REDE DE ÁREA METROPOLITANA (MAN) 21
FIGURA 8 - ARQUITETURA ORIGINAL DE ETHERNET. FONTE: (TANENBAUM, 2002) 22
FIGURA 9 - ARQUITETURA *TOKEN RING* 23
FIGURA 10 - EXEMPLO DE TOPOLOGIA EM ANEL 24
FIGURA 11 – EXEMPLO DE TOPOLOGIA EM BARRAMENTO 24
FIGURA 12 - EXEMPLO DE TOPOLOGIA ESTRELA 25
FIGURA 13 - EXEMPLO DE REDE EM MALHA 26
FIGURA 14 - EXEMPLO REDE PONTO-A-PONTO 27
FIGURA 15 - EXEMPLO DE TELA DE SISTEMA SCADA. FONTE: WWW.THEVERGE.COM 29
FIGURA 16 - EXEMPLO DE REDE DE SISTEMAS SUPERVISÓRIOS. FONTE: (DJIEV, 2003) 29
FIGURA 17 – MODELO DE ARQUITETURA DE REDE INDUSTRIAL PARA AUTOMAÇÃO. 30
FIGURA 18 - TRÍADE CID 33

LISTA DE ABREVIATURAS E SIGLAS

ARPA – *Advanced Research and Projects Agency*

TCI/IP – Transmission Control Protocol/Internet Protocol

OSI – *Open Systems Interconnection*

ABNT – Associação Brasileira de Normas Técnicas

NBR – Normas Brasileiras

ISO – *International Organization for Standardization*

ISA – *The Instrumentation Systems and Automation Society*

IEC – *International Engineering Consortium*

MAC – *Media Access Control*

AP – *Access Points*

P2P – *Peer-To-Peer*

DoS – *Denial of Service*

CLP – Controlador Lógico Programável

SDCD – Sistema Digital de Controle Distribuído

MES – *Manufacturing Execution System*

PIMS - *Process Information Management System*

RTU – *Remote Terminal Unit*

DH – *Data Highway*

SUMÁRIO

1 INTRODUÇÃO 11
1.1 OBJETIVOS 12
1.2 PROCEDIMENTOS METODOLÓGICOS 12
1.3 ESTRUTURA DO TRABALHO 12
2 FUNDAMENTAÇÃO TEÓRICA 14
2.1 REDES DE COMPUTADORES 14
2.1.1 REDES DE COMPUTADORES – PROTOCOLOS 14
2.1.2 REDES DE COMPUTADORES – PROTOCOLOS – MODELO OSI 16
2.1.3 REDES DE COMPUTADORES – TIPOS DE REDES 18
2.2 AUTOMAÇÃO INDUSTRIAL 27
2.2.1 AUTOMAÇÃO – EQUIPAMENTOS E PROTOCOLOS 28
2.2.2 AUTOMAÇÃO INDUSTRIAL – MODELO DE REDE INDUSTRIAL 30
2.3 SEGURANÇA DE REDES 32
2.3.1 ATAQUES – MOTIVAÇÕES E TÉCNICAS 34
2.3.2 ATAQUES – *MALWARES E* OUTRAS AMEAÇAS 35
2.3.3 FALHAS DE SEGURANÇA DA INFORMAÇÃO EM AMBIENTE DE REDE DE AUTOMAÇÃO INDUSTRIAL 37
3 POLÍTICAS DE SEGURANÇA EM REDES INDUSTRIAIS 39
3.1 POLÍTICA DE SEGURANÇA DA INFORMAÇÃO (S.I.) 39
3.1.1 POLÍTICA DE S.I. – PREMISSAS 39
3.1.2 POLÍTICA DE S.I. – DOCUMENTAÇÃO 40
3.1.3 POLÍTICA DE S.I. – REVISÃO 41
3.1.4 POLÍTICA DE S.I. E REDES INDUSTRIAIS 42
3.2 DIRETRIZES INTERNACIONAIS DE S.I. PARA REDES INDUSTRIAIS 43
4 ESCOPO DE SEGURANÇA PARA REDE INDUSTRIAL 45
5 DADOS COLETADOS JUNTO AOS USUÁRIOS DE REDES INDUSTRIAIS 47

6 CONSIDERAÇÕES FINAIS 48

7 REFERÊNCIAS BIBLIOGRÁFICAS 49

APÊNDICE A – QUESTIONÁRIO: SEGURANÇA DE REDES DE COMUNICAÇÃO PARA SISTEMAS DE AUTOMAÇÃO INDUSTRIAL 52

APÊNDICE B – RESULTADOS DO QUESTIONÁRIO: SEGURANÇA DE REDES DE COMUNICAÇÃO PARA SISTEMAS DE AUTOMAÇÃO INDUSTRIAL 60

1 INTRODUÇÃO

Com o aumento dos dispositivos, móveis ou não, conectados em rede e a internet cada vez mais presente e popular no Brasil e no Mundo, atualmente se pode dizer que praticamente não se vive sem estar conectado. O mundo dos negócios, seja uma grande corporação ou um empresário individual, também se insere nesse crescimento mundial da tecnologia. Troca de arquivos, e-mails, comunicados internos, reuniões, seleção de candidatos, enfim, inúmeras atividades diárias são executadas pela conectividade à internet. (Portal GeoBrasil, 2007)

Ambientes Industriais são essencialmente geridos por automação e com o advento da tecnologia, redes e sistemas estão cada vez mais incorporados a eles. Com conectividade entre máquinas, computadores, sistemas industriais e administrativos, em maioria gerenciados por usuários e com ligação à internet.

Tendo a automação um papel de grande importância na sobrevivência das indústrias, garantindo a melhoria do processo produtivo e possibilitando a competição nesse mercado globalizado, onde o concorrente mais próximo pode estar do outro lado do mundo. (Martins, 2012)

E nessa ligação à internet e conectividade dos usuários que intrusões *hackers*, vírus, *spywares* e outros *malwares* aproveitam ou geram brechas para "bisbilhotar", "roubar" ou danificar as redes, industriais ou não.

Visando criar barreiras às essas ameaças virtuais, aumento do controle e a segurança das redes de automação industrial que o uso de Sistemas de Detecção de Intrusão e Sistemas de Prevenção de Intrusão se torna cada vez mais comum em chão de fábrica e nesse tipo de ambiente.

Relacionadas estas situações, surgem os questionamentos principais:

- Como amadurecer o ambiente de rede industrial?
- Como aumentar o nível de segurança nas redes de automação industrial, reduzindo a incidência de paradas?
- Quais os itens (recursos, informações, serviços, ...) devem ser monitorados e/ou merecem atenção especial?
- Existe mesmo a lucratividade, seja por redução de custo, tempo ou outra variável, após adequações e monitoramentos das redes?
- Como assegurar a continuidade segura de tais redes?

1.1 OBJETIVOS

Constitui objetivo geral deste trabalho estudar e relacionar políticas e medidas de segurança da informação que possibilitem e assegurem as comunicações em sistemas de redes computacionais usadas em automação industrial.

Constituem objetivos específicos:

a) Estudar métricas e políticas de segurança da informação em redes de computadores industriais;

b) Investigar as principais falhas de segurança da informação em ambiente de rede de automação industrial;

c) Identificar e criar um escopo de segurança para rede industrial;

d) Modelar um plano básico de continuidade segura da rede de automação industrial.

1.2 PROCEDIMENTOS METODOLÓGICOS

O desenvolvimento deste trabalho respalda-se em livros de Segurança da Informação, Redes de Computadores e Sistemas de Comunicação e Automação Industrial, bem como em normas técnicas NBR ISO/IEC 2001:2005, NBR ISO/IEC 27002:2007, NBR ISO/IEC 27005:2008, descritivos técnicos de fornecedores de soluções de comunicação industrial e nas disciplinas estudadas na graduação e no decorrer do deste curso.

Realizando por meio de questionários online, com públicos-alvo trabalhadores de indústrias dos setores de automação, manutenção elétrica e mecânica e tecnologia da informação, a fim de levantar ameaças, dificuldades e práticas em uso.

Os dados levantados serão confrontados com as melhores práticas e com as normativas e descritivas técnicas a fim de indicar o que está em desacordo e as principais dificuldades, auxiliando no diagnóstico e criação de melhorias.

1.3 ESTRUTURA DO TRABALHO

O TCC está esquematizado da seguinte forma:

O capítulo 2, a seguir, trata do referencial teórico. São abordados os itens Redes de Computadores, Automação Industrial, Segurança das Redes e as conexões entre eles.

O 3º capítulo apresenta as métricas e políticas de segurança da informação em redes de computadores industriais.

O capítulo 4 identifica as bases para criar um escopo de segurança para rede industrial.

O capítulo 5 apresenta os dados coletados junto aos usuários de redes industriais.

O capítulo 6 apresenta as considerações finais, relacionando os principais critérios para modelar um plano básico de continuidade segura da rede de automação industrial.

2 FUNDAMENTAÇÃO TEÓRICA

2.1 REDES DE COMPUTADORES

Em 1969 a *ARPANet* foi desenvolvida pela agência Norte-Americana ARPA (Agência de Pesquisa em Projetos Avançados) a dita primeira rede, com intuito de interligar as bases militares e os departamentos de pesquisa do governo americano.

Desde seu surgimento, a rede *ARPANet* sofre alterações, mas a principal foi o início do uso do protocolo TCI/IP. (ARPANet, 2012)

A partir disso ficaram caracterizadas que uma rede de computadores são estruturas físicas (*hardware*) e lógicas (aplicativos e protocolos) que permite conectividade entre dois ou mais equipamentos computacionais, a fim das mesmas executarem a troca de informações. (Cantú, 2003)

Como dito, redes de computadores são fruto da união entre hardware e software e devido a isso, várias são as designações dos tipos de redes, dos protocolos usados, dos meios de ligação entre eles e dos equipamentos envolvidos.

2.1.1 REDES DE COMPUTADORES – PROTOCOLOS

Em redes, sejam de computadores ou não, tem um papel importante, pois através deles, teremos a interação entre os *hardwares* e os *softwares* envolvidos. Um exemplo de descrição sobre o que é um protocolo, é dado por (Araujo, 2011):

> Para explicar o que são os Protocolos de Rede, eu vou usar um exemplo clássico: pensemos num chinês que não fala português e um brasileiro que não fala chinês. Ambos podem se comunicar usando uma língua em comum, digamos o inglês, que seria algo como um protocolo. Mesmo que ambos não falassem nenhuma língua em comum poderiam usar gestos universais como o dedão para cima indicando "positivo" ou juntar as duas mãos próximas ao ouvido para dizer que está com sono ou dormindo. Os protocolos são justamente estas línguas e sinais universais que permitem aos dispositivos comunicar-se através da rede.

Após isso, pode-se complementar que uma série de protocolos existe no mercado atualmente e os mesmos são arranjados em camadas, conforme sua similaridade na atuação, como exemplifica a Figura 1.

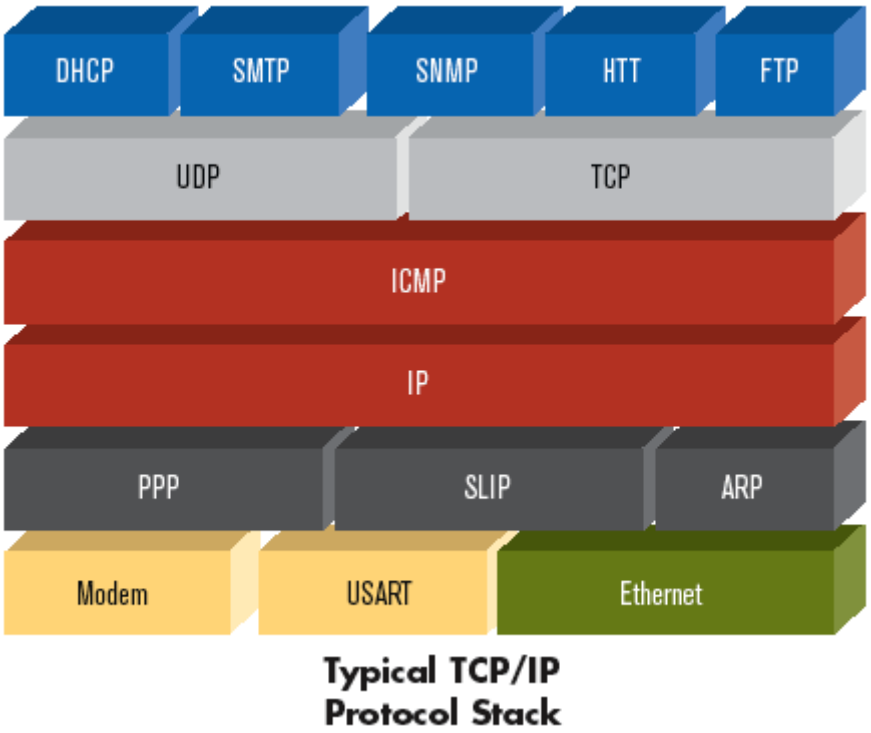


Figura 1 - Arranjo de Protocolos nas camadas. Fonte: (Araujo, 2011)

Devido à variedade de protocolos, existiu a necessidade de alguma padronização e foi criado então o Modelo OSI e segue de guia para o arranjo acima citado.

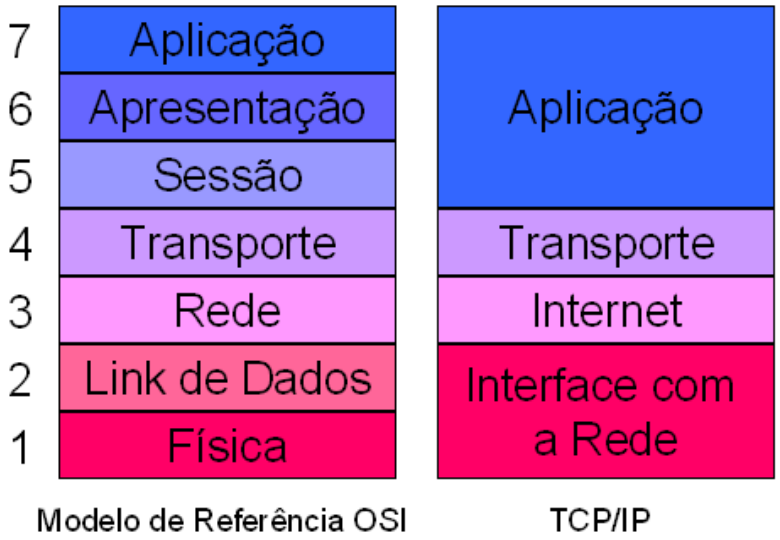


Figura 2 - Comparativo das Camadas OSI e Camadas TCP/IP. Fonte: (Torres, 2007)

2.1.2 REDES DE COMPUTADORES – PROTOCOLOS – MODELO OSI

Com a necessidade de formalização na forma de conectar os computadores, a ISO foi uma das primeiras organizações a emplacar tal, com a arquitetura do Modelo OSI[1] ou camadas OSI como também é conhecido.

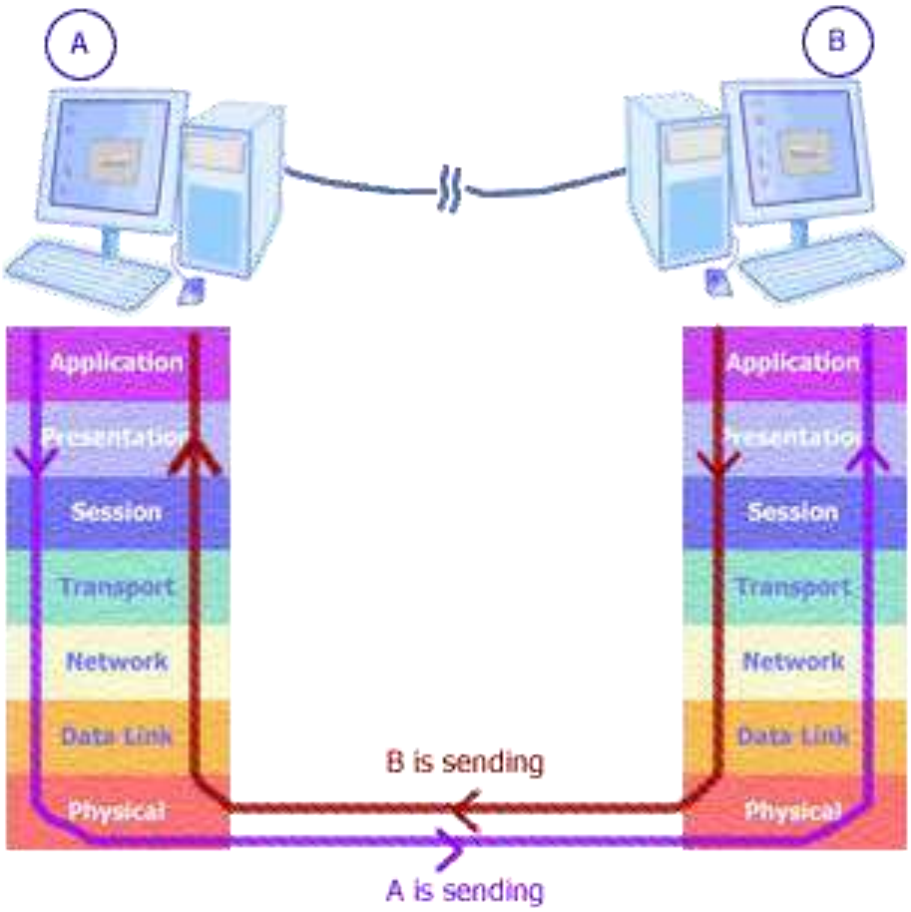


Figura 3 - Camadas OSI. Fonte: (Souza, 2012)

A conectividade entre os equipamentos das redes antes da padronização OSI era um tanto difícil, pois eram inúmeros protocolos diferenciados nas particularidades, que impediam a comunicação direta e forçavam a aquisição de equipamentos específicos para tais. (Araujo, 2011)

As 7 camadas do modelo OSI, apresentadas em ordem decrescente são: Aplicação (7), Apresentação (6), Sessão (5), Transporte (4), Rede (3), Link de Dados (2) e Física (1).

---

[1] OSI em tradução oficial significa Interconexão de Sistemas Abertos.

Cada camada tem uma função diferente e encapsula os dados de um meio diferente para a camada posterior. Nesse encapsulamento a respectiva camada acoplará seu próprio cabeçalho, que é o seu identificador e identificador do conteúdo em tráfego e processamento. Após isso, este encapsulado será enviado a próxima camada, num nível mais baixo, até chegarem no 1º nível, quando estarão prontas para serem transmitidas.

As camadas estão desenhadas como:

- **Camada 7 – Aplicação:** Como seu nome diz, é o aplicativo, o programa utilizado. Essa camada representa todos os programas envolvidos na comunicação da rede e não da rede em si. Essa camada e os programas nela contido utilizam o nível abaixo (6), para comunicar-se pela rede.

- **Camada 6 – Apresentação:** Essa camada serve de preparação para os dados do domínio local e ajuste para um formato compatível com os procedimentos do transporte. É nessa camada que a padronização dos diferentes tipos de dados é ajustada para transporte na rede, indiferente da implementação nas camadas inferiores. É nessa camada que criptografia e compressão de dados são executadas, em geral pela própria aplicação.

- **Camada 5 – Sessão:** É responsável pelo estabelecimento de conexão entre dois computadores em comunicação. Nesta camada que o diálogo entre as aplicações locais e remotas são controlados. Ainda nessa camada que blocos de dados são criados, para envio posterior, caso haja alguma interrupção na conectividade.

- **Camada 4 – Transporte:** Responsável por fornecer meios para que os nós locais e remotos possam trocar informações, é nessa camada que um "túnel" entre a camada 5 local e a camada 5 remota (caso necessário) será criada. É dita como orientada a conexão.

- **Camada 3 – Rede:** Nesta camada a atuação é em nível de hardware, diferente das camadas acima onde a atuação é em software. Esta camada é detentora de toda a topologia e distribuição da rede e com isso sabe como

encontrar um equipamento específico da rede, de forma direta. Diferente da camada de transporte (4), esta não é orientada a conexão. Outra característica desta é que os pacotes de dados enviados por ela, não apresentam garantia de entrega, podendo chegar ou não ao destino.

- **Camada 2 – Enlace:** Responsável pela comunicação direta entre duas interfaces numa mesma rede tem conhecimento exclusivo de sua rede. É a camada responsável pela coleta e entrega de pacotes à interface de rede correta. Também é nesta que a detecção de erros é feita.

- **Camada 1 – Física:** É responsável pelo envio dos *frames* aos meios físicos, ou seja, é feita a conversão do meio em sinal, por exemplo: meio elétrico em sinal elétrico; meio luminoso em sinal luminoso; meio sonoro em sinal sonoro, etc. Esta conversão é feita a partir do sistema binário (0 ou 1).

2.1.3 REDES DE COMPUTADORES – TIPOS DE REDES

Os tipos de redes podem ser diferenciados por: Localização Geográfica, Arquitetura de Rede, Topologia e Meio de Transmissão.

Baseado na Localização Geográfica (Cantú, 2003) descreve as redes como sendo:

- ***LAN*:** *Local Area Network* – Rede de Área Local – são as redes pertencentes a uma mesma organização e interligados entre si em pequena área geográfica. Uma rede local é a representação mais simples de redes e sua velocidade de transferência de dados pode variar entre 10 Mbps e 1 Gbps, de acordo com as configurações dos adaptadores de rede dos equipamentos, onde o padrão dos equipamentos Brasileiros ainda são 100 Mbps.

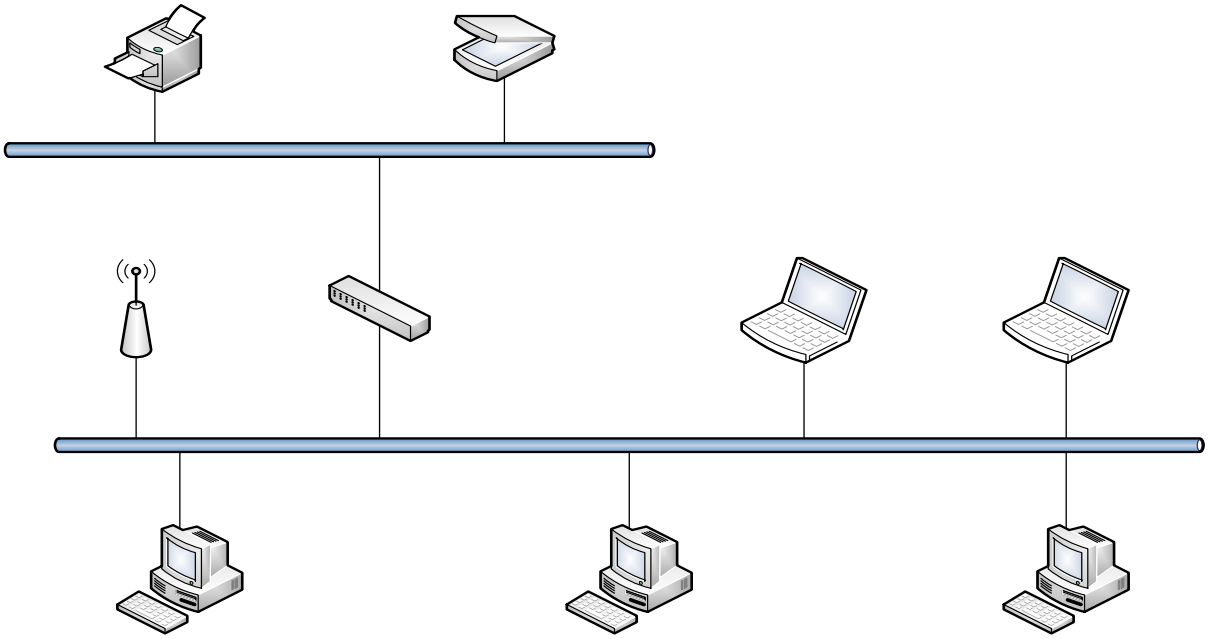


Figura 4 - Exemplo de Rede de Área Local (LAN)

- ***WLAN*:** *Wireless Local Area Network* – Rede de Área Local Sem Fio – similar às redes *Lans*, são as redes pertencentes a uma mesma organização e interligados entre si em pequena área geográfica, porém com conexão sem fio. Esta rede é a comumente usada em Smartphones, Notebooks e outros equipamentos portáteis.

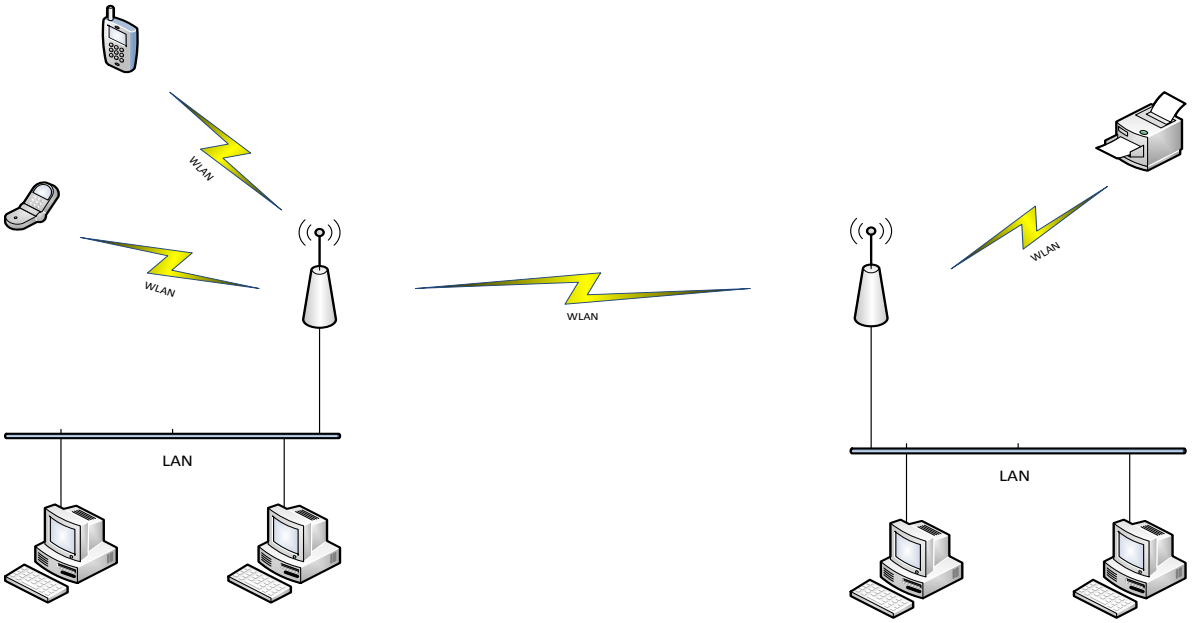


Figura 5 - Exemplo de Rede de Área Local Sem Fio (WLAN)

- ***WAN***: *Wide Area Network* – Rede de Longa Distância – são as redes que abrangem grandes áreas geográficas, interligando redes locais segmentadas, de diferentes localidades. Essas *lans* segmentadas são chamadas de sub-redes. *WANs* surgem e são necessárias devido crescimento das empresas que fisicamente aumentam suas dimensões de atuação, montando escritórios remotos, fábricas estrategicamente posicionadas, *home offices* e outras *lans*, que devem ser interligadas, sendo esse o papel da *WAN*.

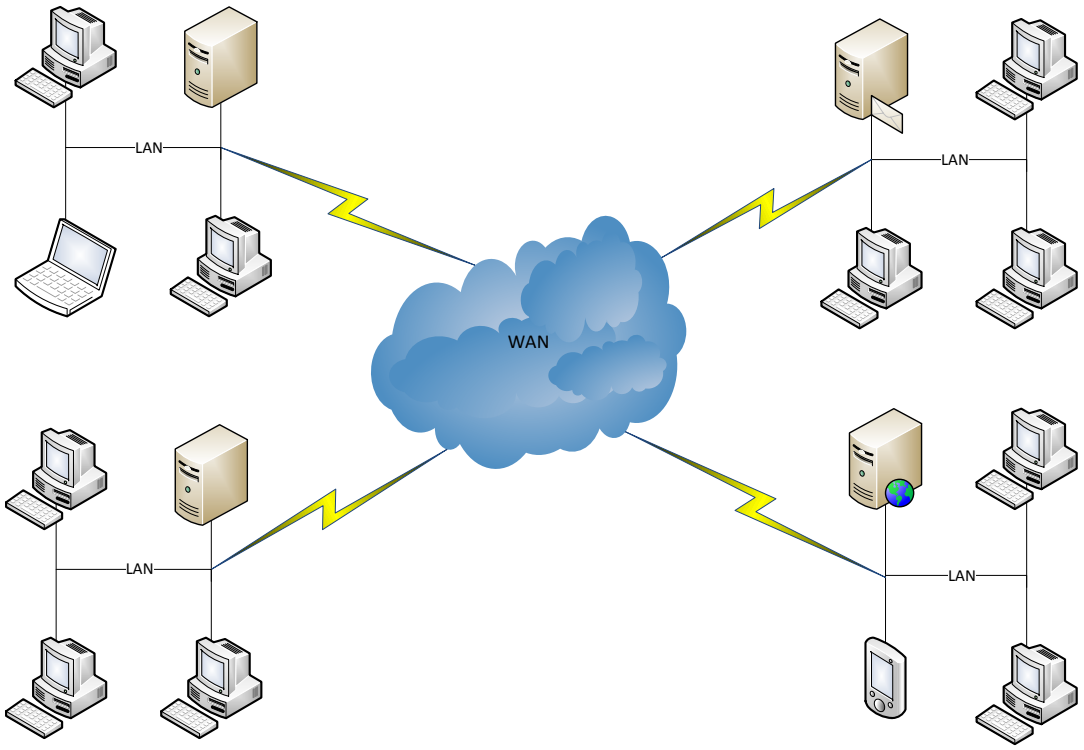


Figura 6 - Exemplo de Rede de Longa Distância (WAN)

- ***MAN***: *Metropolitan Area Network* – Rede de Área Metropolitana – são as redes ocupantes de perímetro de uma cidade. São redes de alta velocidade de trafego que permitem conectividade entre setores de uma mesma cidade (empresas em diferentes bairros e regiões). Esse tipo de rede tem sido difundido principalmente pelas redes de TV a Cabo, para comercialização de sinal de internet e televisivo.

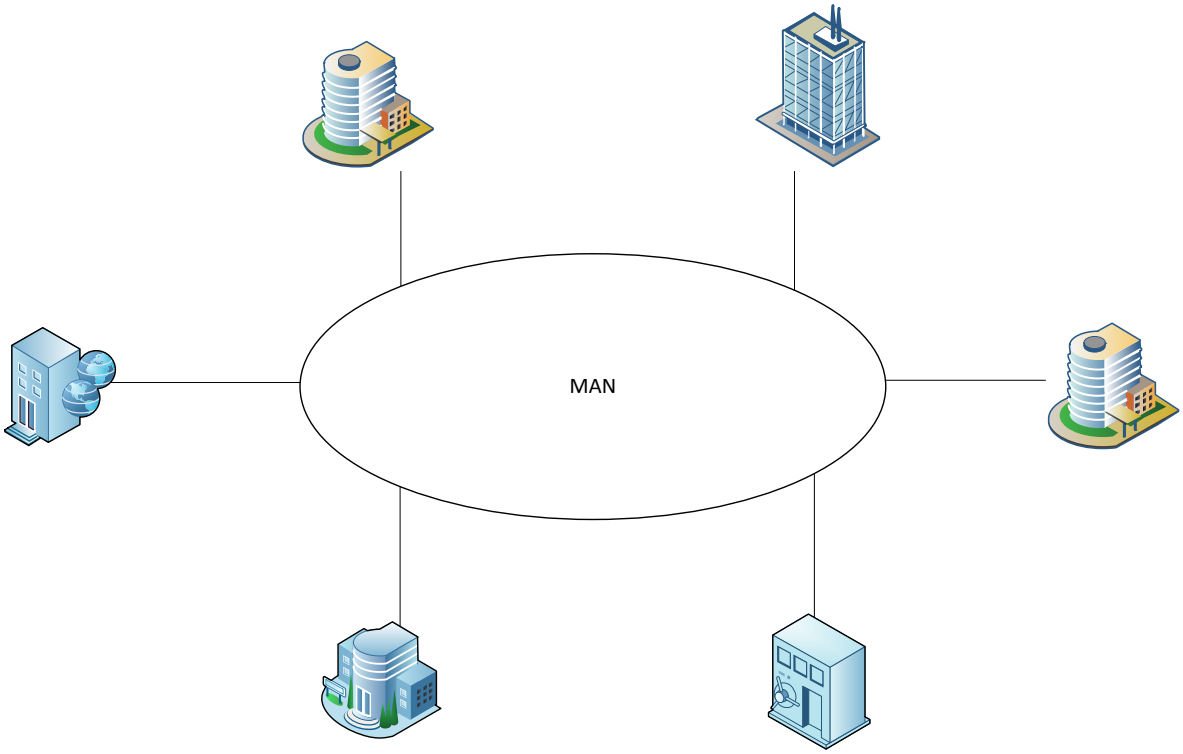


Figura 7 - Exemplo de Rede de Área Metropolitana (MAN)

Os tipos de rede descritos são os principais, mas ainda existem:

- *SAN (Storage Area Network)*
- *PAN (Personal Area Network)*
- *WMAN (Wireless Metropolitan Area Network)*
- *WWAN (Wireless Wide Area Network)*
- *RAN (Regional Area Network)*
- *CAN (Controller Area Network)*

Todos os tipos de redes citados acima são baseados por sua localização geográfica, e com isso cada um tem uma abrangência que minimiza ou maximiza sua utilidade.

Seguindo com os tipos de redes, baseado na sua arquitetura, cita-se:

- ***ARCNET*** – *Attached Resource Computer Network* – Rede de Computador com Recurso Anexado – Assim como *Ethernet* e *Controller Area Network* (*CAN*), *ARCnet* é uma tecnologia de camada de link de dados sem camada de aplicação definida. *Designers* de *Softwares* e/ou Redes escrevem sua própria camada de aplicação para atender às suas necessidades

específicas e muitas vezes não anunciar o fato de que *ARCnet* está sendo usada. *ARCnet* não recebe o reconhecimento do nome, mas é frequentemente a rede de escolha em aplicações embarcadas. Ela está oculta aos usuários, mas possui cerca de 22 milhões de nós comercializados, o que dá credibilidade e torna a *ARCnet* realmente popular.

Com forte atuação no campo da automação de escritórios e indústrias é extremamente popular no Japão, América e Europa e está introduzindo-se na China, por intermédio das Universidades, que cada vez mais a integram em seus projetos. (ARCNET Trade Association, 2002)

- ***Ethernet*** – desenhada como tecnologia de conexão de redes *LAN* baseada no envio de pacotes, passou por algumas mudanças deste seu surgimento e tem em seu formato atual o papel de definição do cabeamento e sinais elétricos da camada Física de protocolos e formato de pacotes e protocolos para *MAC* no modelo OSI.

Este tipo de rede se popularizou e tomou grande parte dos acessos dos demais tipos nas redes *LAN.* (PARC, 2002)

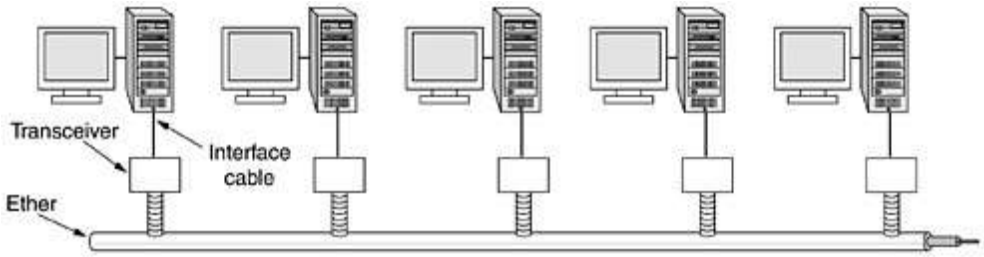


Figura 8 - Arquitetura Original de Ethernet. Fonte: (Tanenbaum, 2002)

- ***Token ring*** – com operação na camada física e de enlace no Modelo OSI (variando de acordo com sua aplicação). Essa topologia trabalha em anel (*ring*), circulando uma ficha (*token*) pelos equipamentos, por isso seu nome. Essa ficha circula infinitamente na rede, descarregando seu conteúdo nos equipamentos destino, mas caso circule no anel todo e não localize o destino, um aviso de erro será reportado ao emissor. Como dito, a circulação é infinita, mesmo que a ficha esteja vazia. Essa característica de circulação infinita cria a dependência de todos os equipamentos estarem interligados e em funcionamento. (CISCO, 2009)

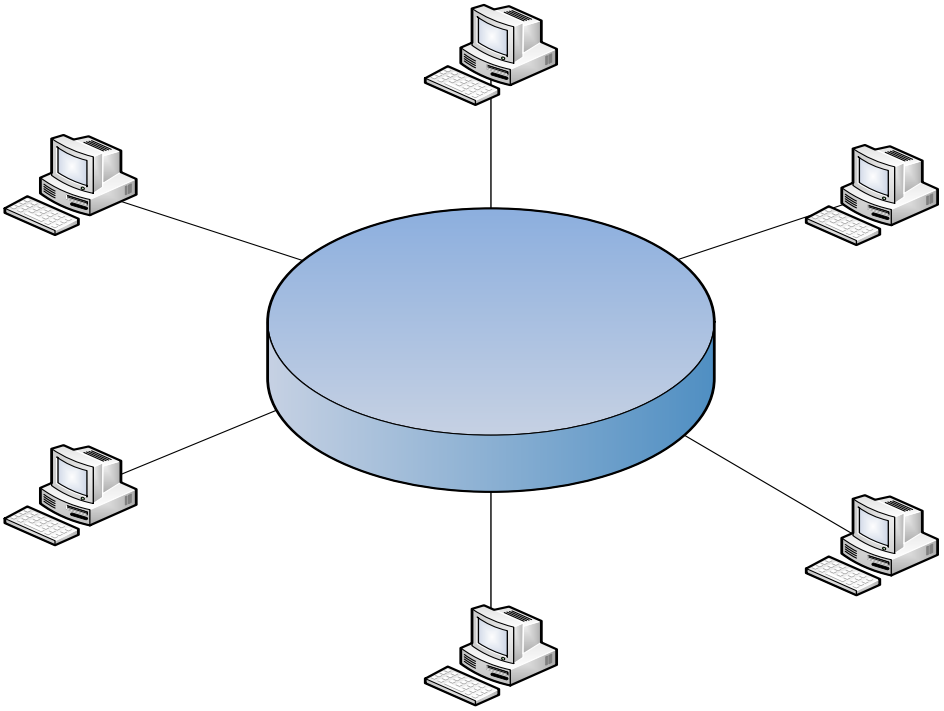


Figura 9 - Arquitetura *Token Ring*

Por se tratarem das principais arquiteturas de comunicação *Lan*, as três tecnologias apresentadas acima (*ARCnet*, *Ethernet* e *Token Ring*) são as principais arquiteturas encontradas em ambientes industriais. (Lugli, et al., 2009)

Porém existem ainda as arquiteturas usadas principalmente em comunicação a longas distancias:

- FDDI (*Fiber Distributed Data Interface*)
- ISDN *(Integrated Service Digital Network*)
- *Frame Relay*
- ATM (*Asynchronous Transfer Mode*)
- X.25
- DSL (*Digital Subscriber Line*)

Também foi citado que os tipos de redes podem variar quanto a sua Topologia, com base em (Tanenbaum, 2002) tem-se:

- **Rede em Anel:** topologia da arquitetura *Token Ring*, é necessário que todos os equipamentos conectorizados estejam ativos para que os dados trafeguem normalmente.

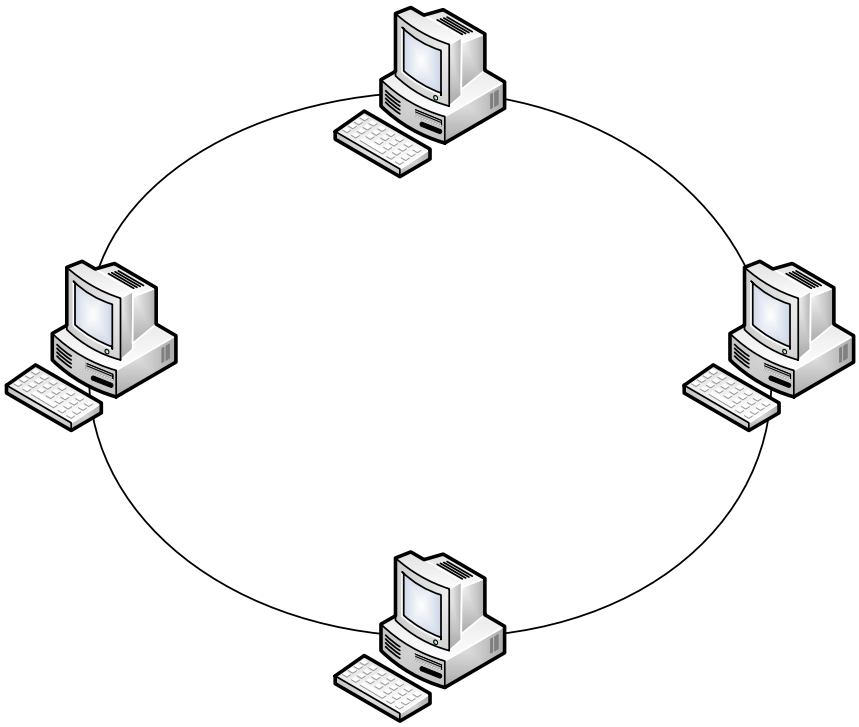


Figura 10 - Exemplo de Topologia em Anel

- **Rede em Barramento:** essa topologia avançou em relação a em Anel, pois independe de todos os equipamentos ativos, porém ainda possui a dependência de apenas um equipamento escrever na rede por vez e os demais apenas leem. Esse tipo de rede incide em muitas colisões, que são os problemas de tentativa de escrita simultânea entre equipamentos.

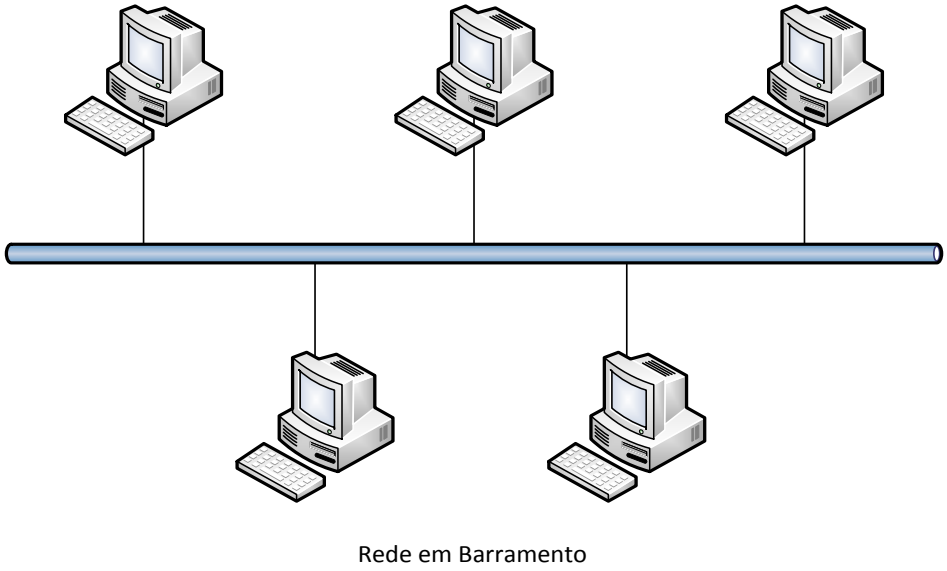


Figura 11 – Exemplo de Topologia em Barramento

- **Rede em Estrela:** essa topologia exige a existência de um concentrador de rede, onde todos os periféricos conectorizados a rede, estarão conectorizados a ele. Esse concentrador é o único a conhecer todos os equipamentos da rede, bem como só ele consegue se conectar a todos.

Esse tipo de topologia é bastante comum, apesar da dependência do concentrador, pois detém um maior tempo de conectividade da rede.

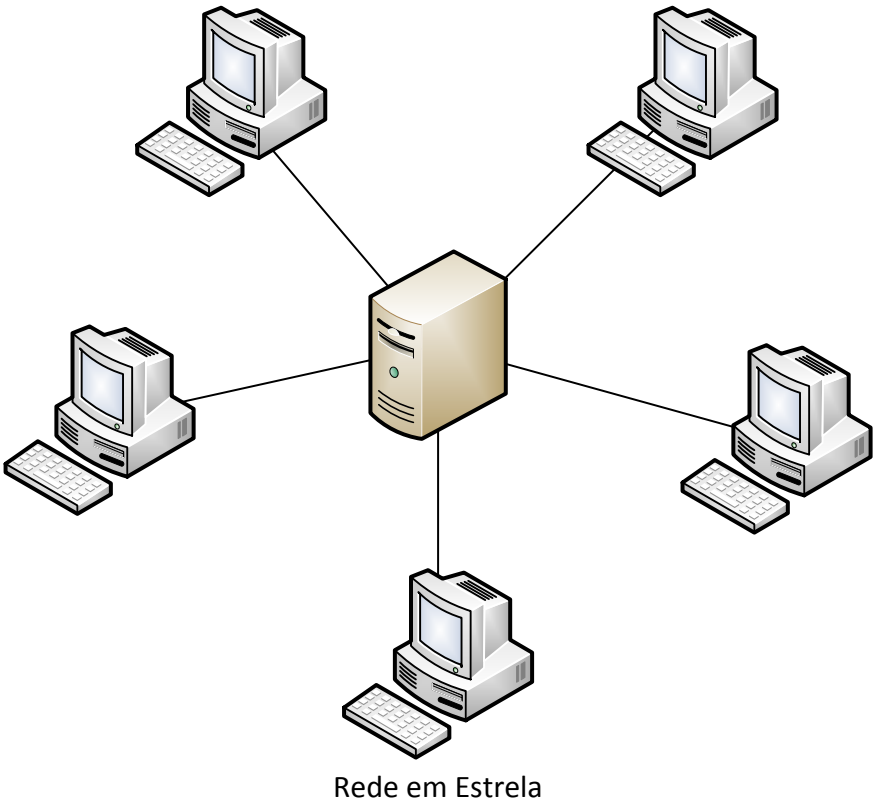


Figura 12 - Exemplo de Topologia Estrela

- **Rede em Malha:** com foco exclusivo a redes sem fio, tem sua infraestrutura composta por *AP's,* onde estes se comunicam entre si, fechando então a malha de comunicação. Um equipamento cliente pode se conectar em qualquer *AP* (integrante da malha) que conseguirá acesso ao conteúdo destino. Estes *AP's* funcionarão como repetidores e pode estar conectado a diferentes malhas, com isso um conteúdo pode ser acessível por diferentes caminhos lógicos e físicos.

Por se tratar de uma tecnologia de baixo custo, fácil implantação e principalmente alta tolerância a falhas e roteamento dinâmico, tem sido

comumente utilizada em ambientes “hostis”, como indústrias, condomínios e ambientes de media distancia.

A Figura 13 representa estações conectadas a *AP’s* e estes conectados entre si. Indiferente da proximidade de um *AP*, a conectividade a ele se dará pela carga que o mesmo estiver carregando, ou seja, se muitos equipamentos estiverem conectados ao mesmo *AP*, este redirecionará os equipamentos para outro.

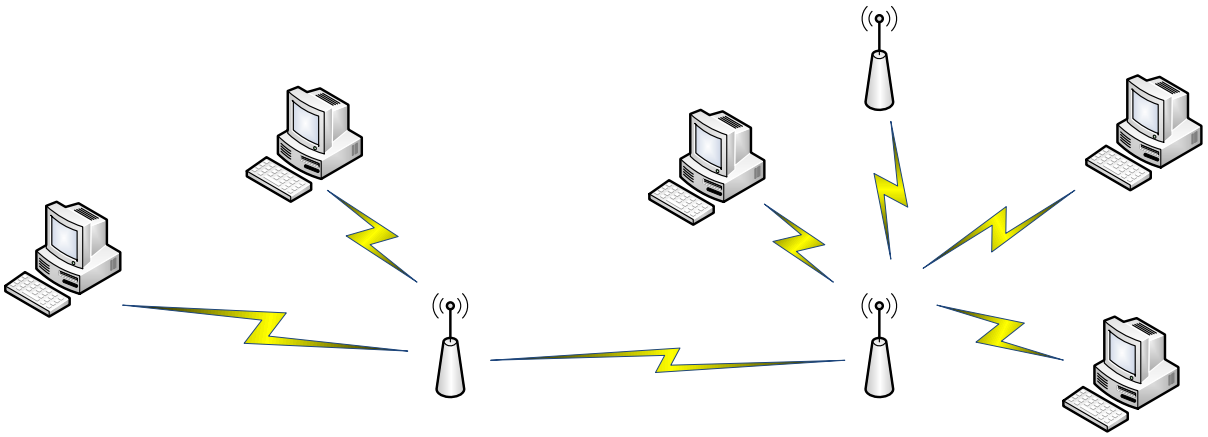
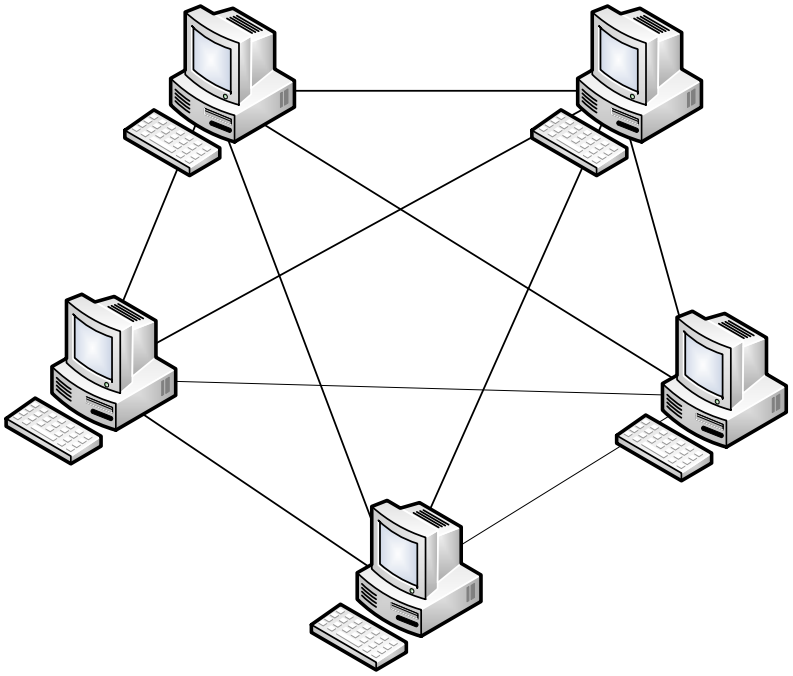


Figura 13 - Exemplo de Rede em Malha

- **Rede Ponto-a-Ponto**: Conforme (Andraschko & Sponholz, 2008):

> A maioria dos sistemas em uso em plataformas WEB são sistemas distribuídos e interagem em uma arquitetura convencional de cliente-servidor, onde cada cliente utiliza um protocolo específico à operação requerida. Essa abordagem concentra as operações no servidor, requerendo assim um equipamento de hardware e um sistema operacional em profunda sintonia com os demais sistemas em execução, pois o aumento de processamentos (diga-se simultâneo) afeta diretamente a desempenho do equipamento e com isso a qualidade de retorno (resultado) do aplicativo ao usuário.
> Rede Peer-To-Peer, ou apenas P2P é uma tecnologia a qual seus estudiosos, desenvolvedores e usuários vislumbram sanar o problema citado, pois a mesma segue a premissa de não concentrar todas as operações em uma única estação (servidor), atuando então no modelo Descentralizado.
> Essa topologia descentralizada auxilia ainda na expansão da rede, pois uma estação (seja computador ou outro equipamento) que possua uma interface de rede capaz de adquirir um endereço IP, pode facilmente ingressar a rede, sem prévia autorização de um servidor, ou mesmo sem que haja alterações na estrutura lógica ou física da rede. Os requisitos para que tal estação ingresse na rede P2P, é possuir um meio de ligação e um aplicativo compatível com o da rede.
> As redes P2P exploram a conectividade entre seus integrantes, utilizando os recursos físicos e lógicos disponíveis (processador, memória, entre outros) do equipamento, fazendo com que a capacidade da rede cresça em larga escala.

Devido à facilidade de ingresso, aos recursos disponíveis e a falta de um servidor central monitorando essas redes, é impossível diagnosticar com exatidão o tamanho atual e o tamanho que uma rede P2P pode atingir.



Rede em P2P

Figura 14 - Exemplo Rede Ponto-a-Ponto

2.2 AUTOMAÇÃO INDUSTRIAL

Automação Industrial é o campo de estudos práticos e teóricos que caracteriza a aplicação de técnicas, softwares e equipamentos, em um determinado processo industrial, sempre objetivando a maximização da produção e o aumento da eficiência da mesma. (Martins, 2012) Cita ainda que automação visa tal maximização, reduzindo ou com o menor consumo de energia e matéria prima possível e com isso a menor emissão de resíduos qualquer que seja a espécie, inclusive humano (mão de obra), assim como melhoria nas condições de segurança. (Martins, 2012) Também refere-se a Automação mão somente como uma mecanização do processo, mas também como o uso da tecnologia eletroeletrônica e computacional para o atingimento dos itens citados e ainda para redução do esforço humano em tais atividades, assegurando-os e aumentando a precisão das atividades.

Na automação três grandes áreas são abordadas:

- **Elétrica**: pelo conhecimento de motores e seus acionamentos e a eletrônica dos comandos e controles.
- **Mecânica**: pelo conhecimento de engrenagens e afins e pela grande capacidade de transformação de matéria-prima em produto acabado
- **Computação:** pelo conhecimento dos bancos de dados, redes e sistemas.

2.2.1 AUTOMAÇÃO – EQUIPAMENTOS E PROTOCOLOS

Atualmente a área mais aparente da automação industrial é a Robótica, porém não somente. Devido a gama de áreas que usufruem da automação, vários são os equipamentos envolvidos na automação industrial. Como citado no item 2.2, eletroeletrônicos ou computacionais faz parte dos equipamentos utilizados em automação industrial, porém destes pode-se destacar os mais comuns, como: CLP's Microcontroláveis e SDCD e tratando-se de redes: *Switch's e* Concentradores, Cabeamentos e Barramentos e Interconectores específicos, além de protocolos próprios como *CAN OPEN, PROFIBUS, MODBUS e Devicenet*[2]. Estes protocolos são ditos próprios por atuarem em conectividade ou controle de equipamentos específicos de automação, como Válvulas, Sensores, Atuadores Mecânicos e Eletromecânicos. Vale ressaltar que tais barramentos atuam de forma específica, mas não isolada, ou seja, conectam equipamentos de automação, porém comunica-se com redes comerciais, principalmente por serem oriundos (em sua arquitetura) de tais redes.

Um item importante ao tratar de redes e sistemas de automação são os sistemas supervisórios ou de supervisão, SCADA (Figura 15), os quais executam exatamente a integração citada no parágrafo acima, fazendo com que processos e outros acompanhamentos sejam difundidos e obtidos tanto a partir dos equipamentos de automação quanto dos sistemas comerciais.

---

[2] Todos estes protocolos têm como protocolos base os tipos comerciais, como Ethernet.

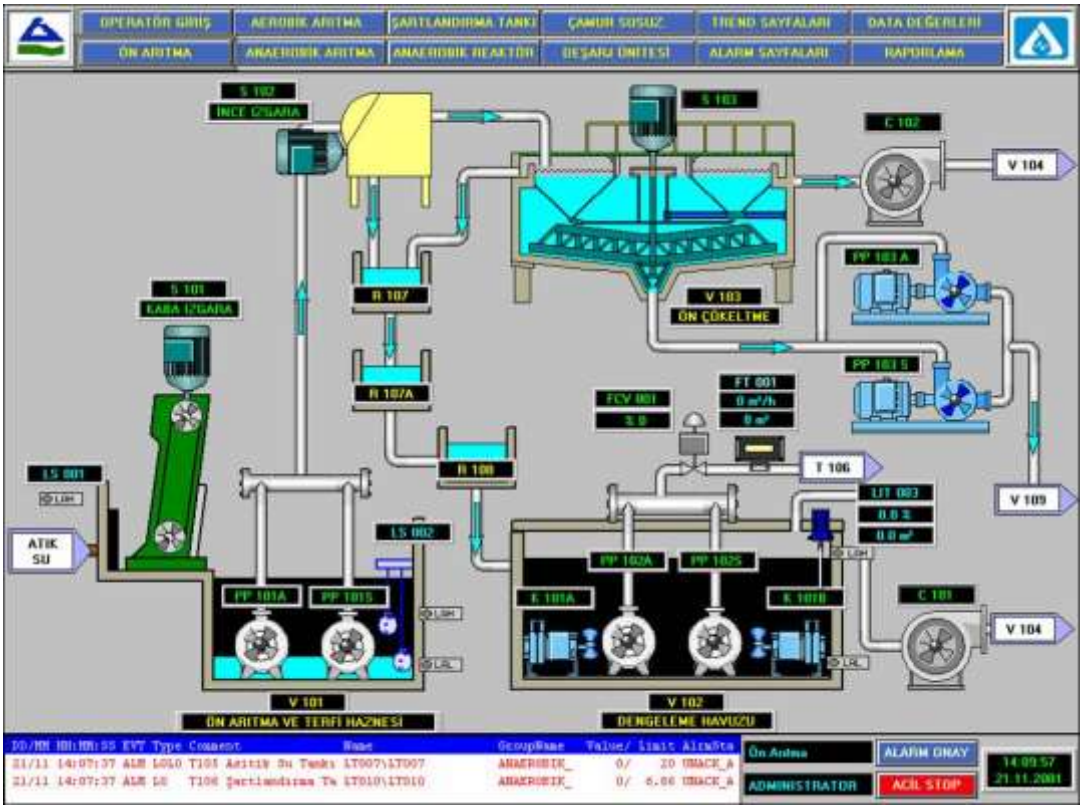


Figura 15 - Exemplo de tela de sistema SCADA. Fonte: www.theverge.com

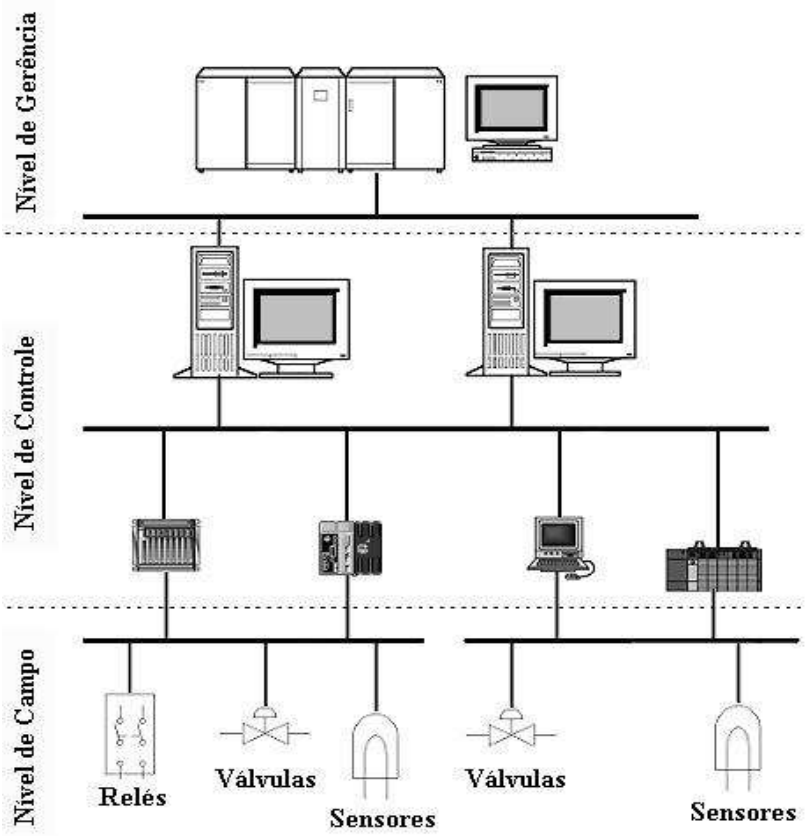


Figura 16 - Exemplo de rede de Sistemas Supervisórios. Fonte: (DJIEV, 2003)

2.2.2 AUTOMAÇÃO INDUSTRIAL – MODELO DE REDE INDUSTRIAL

Assim com as redes de computadores residenciais e comerciais, as redes industriais, interligando equipamentos (máquinas e outros dispositivos) e computadores, promovem o aumento da produtividade e o surgimento de novas oportunidades e novas funcionalidades, além é claro das informações trafegadas, sua confiabilidade e velocidade de transmissão, melhorando para o gerenciamento de produções, melhoria nas configurações de equipamentos, entre outros.

Devido então a essa e outras facilidades, as demandas de tais redes aumentam consideravelmente, como cita (The Internacional Society of Automation, 2012) e devido a isso, propõem um modelo de referência para redes industriais de automação.

Esse modelo é descrito em 6 níveis (sendo do 5 ao 0), como segue:

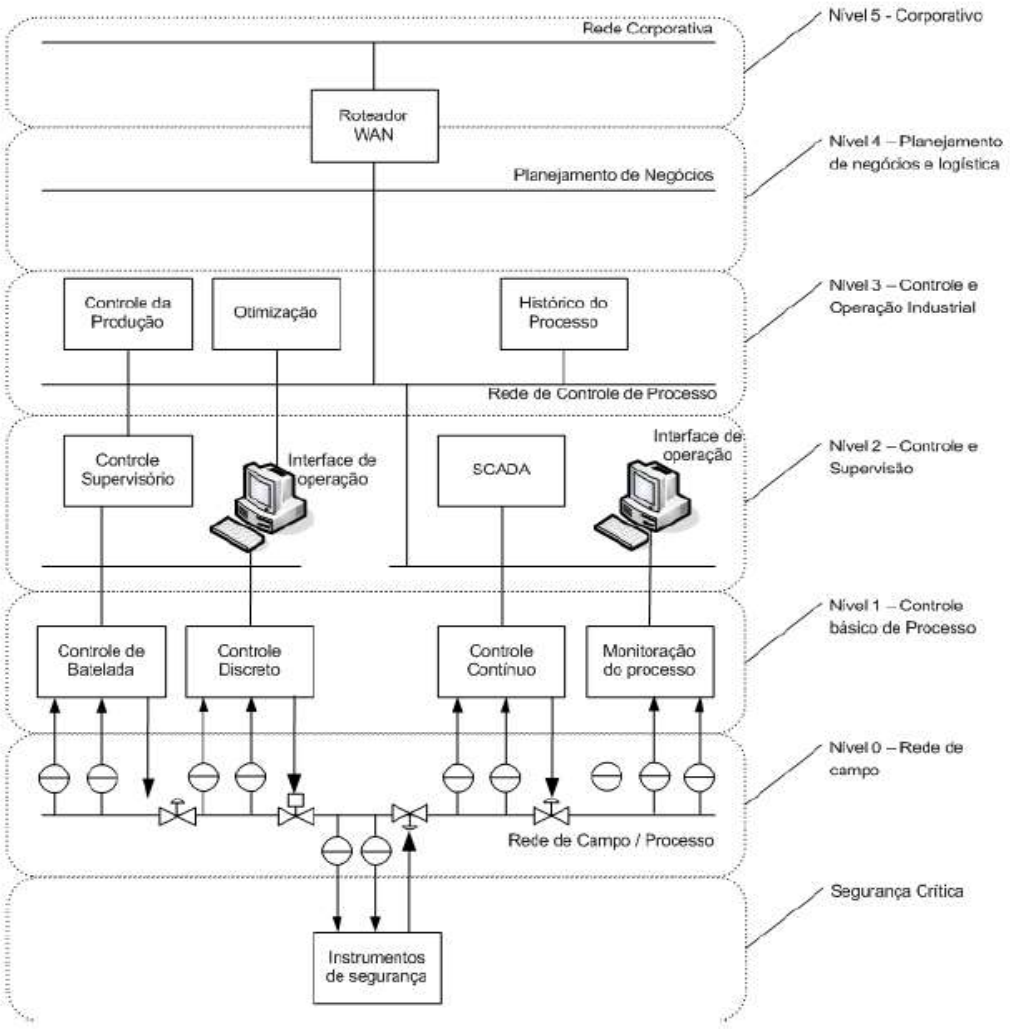


Figura 17 – Modelo de Arquitetura de Rede Industrial para Automação.

Fonte: (The Internacional Society of Automation, 2012)

- **Nível 5 – Corporativo:** Inclui os sistemas corporativos da empresa, como *ERP's SIG's,* Suítes de E-mail, Intranet, entre outros.

- **Nível 4 – Planejamento de Negócios e Logística:** Inclui Sistemas de Planejamento da Produção, Gerenciamento Operacional, Gerenciamento de Manutenção e Inspeção, Sistemas *MES*.

- **Nível 3 – Operações de Manufatura e Controle:** Inclui Sistemas de Planejamento detalhado de Produção, Geração de Dados Históricos (*PIMS*), Análise offline dos dados para funções de suporte de engenharia, otimização de custos para áreas de produção específicas, consolidação de relatórios de produção.

- **Nível 2 – Operação, controle e supervisão**: Inclui as funções de operação da planta de produção. Os sistemas deste nível são responsáveis por prover uma interface homem-máquina para o operador, gerar alarmes e alertas para o operador, funções de controle e supervisão e gerar dados históricos com curto período de armazenamento. Os protocolo de redes do nível 2 são: *FieldBus HSE, PROFInet, EtherNet/IP, Modbus/TCP, OPC.*

- **Nível 1 – Controle básico de processo: I**nclui os equipamentos de controle e monitoração, ligados aos sensores (instrumentos de medição de variáveis de processo) e elementos finais de controle do processo (válvulas de controle, motores elétricos e outros). Equipamentos de monitoração são responsáveis pela leitura dos dados dos sensores e assegurando o histórico de processo. E os equipamentos de controle são responsáveis pela leitura dos dados dos sensores, enviando dados para o elemento final de controle e assegurando o histórico de processo. Neste nível estão os *SDCD*'s, *CLP's* e RTU's e os protocolos de rede são: *DH+, DeviceNet, Modbus/TCP.*

- **Nível 0 – Rede de campo:** Sendo este o nível primário da rede industrial, está disposto em chão de fábrica e inclui os sensores e elementos finais de controle que são conectados ao processo ou aos equipamentos de um processo industrial. Os sensores são responsáveis por medir a variável do processo (pressão, temperatura, nível, fluxo e outros) e convertê-la em um sinal padrão a ser enviado ao equipamento de controle. Os transmissores, os

analisadores e os transdutores, são exemplos de sensores. E os elementos finais de controle, são responsáveis por receber o sinal de correção do controlador, e atuar no processo, de modo a manter o equilíbrio desejado do processo. As válvulas de controle e os motores elétricos são exemplos deste tipo de equipamento. Protocolos de redes deste nível: FieldBus H1, Profibus PA, Profibus DP, AS-i, Modbus/TCP.

2.3 SEGURANÇA DE REDES

Segurança de redes, como próprio nome diz, é a área de redes responsável pela segurança, seja ela das informações trafegadas como da própria rede física.

Essa área de redes tem em seu escopo o desenho, provisionamento, execução e manutenção das políticas e ações englobadas pelas mesmas, tais como:

- Segurança preventiva
- Segurança reativa
- Técnicas de Ataque
- Ataque Interno
- Ataque por *Spoofing*
- Ataque por *Sniffer*
- Ataque por *DOS*
- Ataque por *Malware*
- Ataque por Vírus
- Ataque por *Spam*
- Ataque por *Worm*
- Ataque por *Trojan*
- Ataque por *Spyware*
- Ferramentas de Segurança
- Auditoria de Segurança
- Segurança Física

Existem outros itens abordados pela segurança de redes e de informações que trafegam pelas redes, onde (NIC BR Security Office, 2003) cita que todos eles se baseiam na tríade:

- Confidencialidade
- Integridade
- Disponibilidade

Figura 18 - Tríade CID

Ainda existem autores, como exemplo (Bishop, 2002) que citam um quarto elemento:

- Autenticidade

O objetivo dessa tríade ou quádrupla é assegurar ou minimizar que acessos, modificações, serviços e dados sejam usurpados, roubados e/ou disseminados de forma ilícita, descontrolada e desgovernada pelas redes, tornando-as um local inseguro e não confiável (Bishop, 2002).

Em (NIC BR Security Office, 2003) é apresentado um documento padrão de segurança da informação de uma rede, cobrindo uma variedade de redes, públicas e privadas, indiferente da natureza econômica, financeira, física e de produtividade, sendo uma documentação padronizada pela norma ISO/IEC 27002:2005 (para fins de registros de continuidade da norma, também pode ser dita ISO/IEC 17799:2005, (International Organization for Standardization, 2005).

2.3.1 ATAQUES – MOTIVAÇÕES E TÉCNICAS

Ataques a redes de computadores são efetuados de diversas formas e com diversos propósitos. Atualmente qualquer equipamento que esteja conectado a uma rede, principalmente se conectado à internet, está sujeito a um ataque, assim como pode participar de um ataque. (Comitê Gestor da Internet no Brasil, 2012)

Os principais motivos de ataques às redes são:

- **Demonstração de Poder**: Mostrar que a rede pode ser invadida e assim obter vantagens contra o proprietário da mesma.
- **Prestígio**: Vangloriar-se perante outros atacantes do feito.
- **Motivações Financeiras: C**oletar e utilizar informações confidenciais, aplicando golpes.
- **Motivações Ideológicas:** Ir contra redes que exponham conteúdo de opinião contrária a sua.
- **Motivações Comerciais:** Tornar redes de concorrentes inacessíveis, comprometendo a reputação destas empresas.

Para atingimento destes motivos inúmeras técnicas podem ser usadas, onde as mais comuns são:

- **Exploração de Vulnerabilidades:** visa buscar uma brecha de segurança na aplicação e/ou rede, onde o resultado é a violação da mesma, como por exemplo: Falhas de Projetos, na implementação ou configuração de aplicativos, serviços ou equipamentos de rede.
- ***Scan:*** varredura em rede consiste em efetuar buscas minuciosas a fim de identificar equipamentos ativos e coletar suas informações. Com base nestas informações outros tipos de ataques poderão ser usados, como por exemplo, a Exploração de Vulnerabilidades. *Scan* quando associada a Exploração de Vulnerabilidades pode ser usada de forma **Legítima** quando se testa a segurança do ambiente e de forma **Maliciosa** quando é usada como forma de ataque.
- **Falsificação de Email**: consiste em alterar campos de cabeçalho de e-mail, de forma a apresentar o mesmo como se fosse enviado por outra pessoa, ou seja, como se alguém conhecido estivesse enviando.

- ***Sniffing***: Interceptação de Tráfego consiste em inspecionar os dados trafegados na rede e assim como *Scan*, apresenta a forma **Legítima**, quando usada para detecção de problemas e **Maliciosa** quando usada para ataques e furtos de conteúdo.
- **Força Bruta**: consiste em forçar a descoberta da senha, nome de usuário ou outro item de segurança, por tentativa e erro e assim obter acesso irrestrito com altas permissões ao ambiente atacado. Este tipo de ataque, mesmo se sem sucesso, pode acarretar outros problemas, pois pode causar indisponibilidade no ambiente se exposto por muito tempo em atividade maliciosa.
- **Negação de Serviços:** O objetivo deste ataque não é a invasão, mas sim a inoperância do atacado, como por exemplo, "derrubar" um servidor ou site, principalmente pelo excesso de comunicações e conexões.

2.3.2 ATAQUES – *MALWARES E* OUTRAS AMEAÇAS

Assim como no item anterior (2.3.1), *malwares* faz parte do escopo da Segurança de Redes, sendo um item abordado em separado, principalmente pela quantidade de causadores encontrados nas redes, pelos estragos feitos e pela dificuldade de eliminação (parcial ou completa) sem danos aos atacados. (Norton Brasil, 2012)

Dentre os *malware,* os mais comuns e disseminados são:

- **Vírus:** na Biologia vírus é tratado como uma ameaça muito pequena que atinge e usufrui de sistemas mais complexos para sua sobrevivência, como refere (International Committee on Taxonomy of Viruses, 2012). Na Computação os vírus seguem exatamente essa prática, sendo que os mesmos visam infectar o sistema, se aproveitando do mesmo para se multiplicar e disseminar-se pela rede. A principal via de liberação e proliferação dos vírus é diretamente pelos usuários, por meio de mídias, e-mails e arquivos infectados e também sistemas desatualizados e com vulnerabilidades aparentes. Uma característica do vírus é que, em geral, ele depende de outro aplicativo ou sistema ou até mesmo hardware e usuário para sua difusão.

- ***Worm:*** ou verme em português, caracteriza-se por ser semelhante a um vírus, porém sem a necessidade de outro aplicativo para propagar-se. Devido a esta caraterística auto replicante pode ser prejudicar em massa, rapidamente, destruindo redes, arquivos, sistemas e outros.
- ***Spam:*** termo usado para referir-se a e-mails não solicitados, geralmente enviados em massa, ou seja, a um grande número de usuários, seu conteúdo pode conter alguma ameaça ou ser meramente comercial. (Neste segundo caso, spam também é chamado de UCE – *Unsolicited Commercial E-mail* – E-mail Comercial Não Solicitado). Já como item realmente malicioso, *spam* pode agregar outros maliciosos, como *keylogger, trojans,* cavalos de tróia e outros e é um atrativo "parceiro", pela sua principal característica, a base de conhecimento de contatos de usuários e dispositivos.
- **Cavalo de Tróia:** Também conhecido como Trojan, assim como na lenda de tróia este *malware* visa à entrada ao equipamento/sistema sem suspeitas, para que possa então liberar o acesso a uma possível invasão de outro *malware*, este sim realmente nocivo. Este tipo de ameaça, sozinho, não causa danos ao atacado, porém evidência as vulnerabilidades do sistema e/ou se aproveita da interação do usuário.
- ***Backdoor:*** *malware* com intuito de permitir a invasão de um sistema por um Cracker[3] para que o mesmo obtenha controle total sobre equipamento ou software afetado. Em geral este tipo de *malware* serve apenas como porteiro para outros maliciosos (vírus e *worms*, por exemplo).
- ***Spyware:*** sendo este um programa automático, que visa a absorção dos dados do usuário, como seus dados pessoais, costumes, tipos e locais (websites) de acessos e os transmite para o invasor proprietário, para que o mesmo utilize tais informações para causas maiores como um segundo ataque. Este tipo de *malware* difere dos *Trojans* por não terem como objetivo o domínio do sistema, ao contrário, ele depende que o sistema esteja livremente em uso pelo usuário para que sejam coletados os seus dados pessoais.

---

[3] Cracker: tipo de hacker (invasor) o qual visa destruição, roubo ou deleção do sistema ou de suas informações.

- ***Keylogger:*** sendo um tipo de spyware, sua finalidade é registrar tudo que é digitado, com intuito de capturar senhas, números de cartões de créditos e contas correntes e outros. O uso deste nocivo é uma das principais causas de ataques com perdas financeiras e faz com que as instituições bancárias cada vez mais se preocupem com eles, criando mecanismos contra a leitura de teclas pressionadas ou sensíveis a toques.
- ***Exploit:*** é um conjunto de comandos ou programas usados para fins nocivos, de invasão. Esta série de comandos é usada para a explorar as vulnerabilidades e falhas dos sistemas, assegurando a entrada do invasor. Em geral os métodos de exploração não são divulgados e seu uso em massa se deve aos atacantes menos experientes, conhecidos como *Script Kiddies* e conhecedores das técnicas de ataque e das vulnerabilidades dos sistemas.
- **Ataques Internos:** é o tipo de ataque onde não precisa existir um software nocivo. O Ataque interno é caracterizado quando usuários autorizados ou não, efetuam ações maliciosas. Este tipo de ataque já é mais danoso que muitos ataques externos.

2.3.3 FALHAS DE SEGURANÇA DA INFORMAÇÃO EM AMBIENTE DE REDE DE AUTOMAÇÃO INDUSTRIAL

O avanço e a facilidade de acesso tecnológico, como já citado, é um atrativo ao conhecimento das redes, de seus protocolos e estruturas e de novas tecnologias e com isso a exploração de suas vulnerabilidades e ao descobrimento de suas falhas, (Runge Filho, 2012).

No ambiente de rede industrial, principalmente da automação industrial, por agregarem uma gama de itens suscetíveis a falhas, as vulnerabilidades são mais aparentes. Porém alguns desses itens requerem destaque (distintas pelo meio de ação):

- Físicas:
  a) Aumento de redes (cabeamentos, switches e outros periféricos) conectados aos Sistemas SCADA;
  b) Instalações inadequadas;

c) Falta de equipamentos de segurança (extintores, detectores de fumaça, controle de humidade e temperatura, etc.)
d) Desorganização de cabeamentos e equipamentos;

- Hardware:
  a) Defeito de Fabricação;
  b) Defeito de Configuração;
  c) Má conservação do equipamento;
- Software:
  a) Aumento de Aplicativos conectados aos Sistemas SCADA;
  b) Falta e Falha no controle de acesso aos Sistemas;
  c) Falha na programação dos Sistemas;
- Armazenamento de Dados:
  a) Mídias externas (HD externo, DVD, Pen-drive, cd-roms, etc.) sem controle de uso;
- Comunicação:
  a) Falha ou ausência na comunicação de dados entre periféricos e sistemas (podendo ser por questões de software, hardware ou físicas (ambiente)).
- Humana:
  a) Falta de conhecimento técnico dos sistemas, equipamentos, mídias externas, ou seja, do conjunto todo que envolve o ambiente tecnológico.
  b) Conhecimento excessivo do ambiente, agregado a falha de controle de acesso, deixando o ambiente suscetível a coleta e disseminação indevida das informações.

Todas essas vulnerabilidades, agregadas as pragas e ataques virtuais (item 2.3 acima) tornam o ambiente das redes de automação industrial falho.

3 POLÍTICAS DE SEGURANÇA EM REDES INDUSTRIAIS

3.1 POLÍTICA DE SEGURANÇA DA INFORMAÇÃO (S.I.)

A (International Organization for Standardization, 2005) define que uma Política de Segurança da Informação (S.I.) tem por objetivo prover à direção da companhia uma orientação e apoio à segurança da informação através da emissão e manutenção da política à toda organização.

Baseado na descrição da (International Organization for Standardization, 2005), pode-se expandir a política de segurança da informação, onde se deve ter um documento bem definido e difundido a toda a organização, visando assim o conhecimento de todos e mais, visando o entendimento e a integração de todos na prática das mesmas, sem distinção funcional do colaborador e com isso atuar na democratização e difusão do conhecimento, sem, ou melhor, minimizando os impactos nocivos às redes e bases de dados e informações.

3.1.1 POLÍTICA DE S.I. – PREMISSAS

Entendida a necessidade de uma política de segurança da informação, se faz necessário que algumas premissas sejam vistas, pois só assim assegurar-se-á que as boas práticas já existentes sejam seguidas e assim impactos negativos surjam antes mesmo da difusão do documento de política de segurança da informação.

Essas premissas são elaboradas por órgãos respaldados e responsáveis pela padronização (nos seus países de origem ou em âmbito mundial):

- Obtenção dos procedimentos, normas e padrões (ABNT, SOX, ISO, etc.).
- Entender as necessidades da empresa
- Obter informações sobre os ambientes de negócios

Conforme (Runge Filho, 2012), após entendidas essas premissas, pode-se então partir ao desenvolvimento do conteúdo (documento) das políticas de segurança da informação.

3.1.2 POLÍTICA DE S.I. – DOCUMENTAÇÃO

Dito anteriormente, a política orientará a direção da empresa, por isso o ideal é que o documento da política seja se não escrito com participação, aprovado pela direção ou gerência ou outro cargo de alta gestão. Novamente frisa-se que o documento deve ser difundido e estar ao alcance de todos e que seja de conhecimento de todos.

As informações mínimas sugeridas por (International Organization for Standardization, 2005) são:

- Definição de segurança da informação, resumo das metas e escopo e a importância da segurança como um mecanismo que habilita o compartilhamento da informação;
- Declaração do comprometimento da alta direção, apoiando as metas e princípios da segurança da informação;
- Breve explanação das políticas, princípios, padrões e requisitos de conformidade de importância específica para a organização, por exemplo:
  a) Conformidade com a legislação e cláusulas contratuais;
  b) Requisitos na educação de segurança;
  c) Prevenção e detecção de vírus e software maliciosos;
  d) Gestão da continuidade do negócio;
  e) Consequências das violações na política de segurança da informação;
  f) Definição das responsabilidades gerais e específicas na gestão da segurança da informação, incluindo o registro dos incidentes de segurança;
  g) Referências à documentação que possam apoiar a política, por exemplo, políticas e procedimentos de segurança mais detalhados de sistemas de informação específicos ou regras de segurança que convém que os usuários sigam.

Os itens listados acima também são referenciados por (Runge Filho, 2012) como itens obrigatórios da documentação, numa forma mais simples e entendível, “traduzida na linguagem” do usuário:

- **Utilização dos Recursos de TI**: Utilizar os recursos tecnológicos estritamente para fins profissionais;

- **Titularidade das informações da Empresa**: Definir que todos os dados e informações pertencem à empresa;
- **Segurança das informações / Sigilo da Informação**: Definir quais dados e informações são confidenciais;
- **Estações de trabalho**: Sempre bloquear quando o usuário se ausentar, senhas, definir utilização de CD, USB, etc;
- **Proteção contra *Malwares***: Manter sempre atualizado o antivírus;
- **Softwares não homologados**: Respeitar as licenças e autorizações para uso de software;
- **Criptografia**: Métodos de mascarar os dados, por exemplo, Assinatura digital;
- **Advertências:** Discriminar os níveis de punições (leves, médias e graves) e os casos em que são aplicáveis;
- **Procedimentos para acesso à internet:** Regras de navegação, onde devem ser criados os níveis de acesso, os conteúdos permitidos, gerar e armazenar o histórico de navegação, bem como o equipamento e usuário de navegação;
- **Termos de Responsabilidade e de Confidencialidade:** Tornar público o documento, fazendo com que todos os colaboradores tomem ciência de sua existência e façam uso do mesmo, comprovando o recebimento do mesmo e dos direitos, deveres e punições constantes em tal documentação.

3.1.3 POLÍTICA DE S.I. – REVISÃO

Para que a política tenha efetividade, é preciso que tenha um gestor ou comitê que seja responsável por sua revisão, análise crítica e manutenção, de acordo com regras já definidas e alinhadas com o negócio. Também é preciso que este processo garanta que a análise crítica ocorra como decorrência de qualquer mudança que venha a afetar a avaliação de risco original, tais como um incidente de segurança significativo, novas vulnerabilidades ou mudanças organizacionais ou na infraestrutura técnica.

Esta análise crítica deve ter uma agenda definida e com itens de revisão definidos, para que não caia em desatualização ou não conformidade com o negócio e suas áreas:

- Efetividade da política, demonstrada pelo tipo, volume e impacto dos incidentes de segurança registrados;
- Custo e impacto dos controles na eficiência do negócio;
- Efeitos das mudanças na tecnologia.

3.1.4 POLÍTICA DE S.I. E REDES INDUSTRIAIS

Entendidas e definidas as políticas de segurança da informação, bem como difundidas entre os colaboradores, transportá-las ao ambiente industrial torna-se automático e facilitado.

Aproveitando-se as regras gerais, tais como compartilhamento e confidencialidade dos dados e outros citados no item acima, algumas regras exclusivas para políticas de segurança de redes industriais devem ser incluídas. Esta inclusão é necessária e capaz, por passarem por um processo evolutivo diferenciado, um processo evolutivo das 3 áreas já citadas, da automação.

Essa evolução caracteriza uma nova visão e melhora de muitos processos e com isso o aumento do retorno financeiro. Contudo esse avanço é acompanhado por todos os avanços da tecnologia da informação, inclusive as periculosidades.

Dito isso e como já citado, as redes industriais estão cada vez mais integradas as redes comerciais, o que faz realmente com que as inseguranças que antes eram isoladas das redes industriais, estejam cada vez mais frequentes, principalmente as vindas pela web e internet.

Com isso os itens a serem incluídos na política de segurança para redes industriais devem ser:

- Acompanhamento tecnológico e de pessoas baseado em normas de segurança NBR e de outros órgãos (quando por exigência do cliente ou das atividades em exercício).

  Ex1: Atuação na manipulação de equipamentos elétricos: NBR 10.

  Ex2: Atuação com risco ao Meio Ambiente: ISO 14001.

- Gerenciamento de Continuidade do Serviço baseado não somente nos equipamentos de TI, mas principalmente nos equipamentos responsáveis pelos repositórios e de automação.
- Monitoramento individualizado ou apartado do monitoramento da rede de geral de TI (diga-se como rede comercial para efeito de visualização), aumentando o controle sobre anomalias e também diagnósticos e a garantia de ininterrupção.
- Restrição de pessoas aos dados vitais das redes industriais e sua manipulação (este item redunde à política de S.I., porém é importante citá-la, pois 3 áreas da automação industrial serão envolvidas e devem delas partir a responsabilidade de controle e manutenção dos dados, ficando a TI isenta – exceto pelo armazenamento dos dados).
- Deveres e direitos bem definidos e rígidos ao uso de equipamentos de TI do ambiente de automação, principalmente no que tange a licenciamento, acesso internet e intranet e demais, pois se trata de um ambiente extremamente delicado (por sua criticidade e singularidade) e muitos destes acessos serem hostis ao ambiente em questão. Ex: Acesso a Webmail em computador do *SCADA*.

Agregados estes itens à política ou criada uma política de segurança adicional para o ambiente Industrial serão minimizadas hostilidades e inseguranças das redes industriais.

3.2 DIRETRIZES INTERNACIONAIS DE S.I. PARA REDES INDUSTRIAIS

No Brasil ainda não existe uma diretriz ou norma específica para Segurança da Informação em Redes Industriais, por isso, utiliza-se das políticas padrões de S.I. adequando-as a este ambiente. Porém a comunidade internacional, detém algumas normativas.

Especificamente a (ISA - The Instrumentations, Systems and Automation Society, 2004), regula a norma ANSI/ISA 99, a qual visa estabelecer Segurança da Informação para Redes Industriais e a (NIST - National Institute of Standards and

Technology, 2012) estabelece um guia para Sistemas de Controle de Segurança para Industrias (ICS) através da NIST 800-82.

Ambos os documentos são a base internacional para S.I. em redes industriais, mas ainda não estão com uso frequente no Brasil e isso é evidenciado pela ausência de referências das normativas nos editais publicados em licitações e/ou nos manuais de fabricantes/prestadores de serviço nacionais.

4 ESCOPO DE SEGURANÇA PARA REDE INDUSTRIAL

Com base no citado nos itens anteriores deste trabalho, principalmente no que tange as normais internacionais (ANSI/ISA-99 e NIST 800-82), Diretrizes Internacionais de S.I. para Redes Industriais - cap. 3.2, temos como ações relevantes ao escopo de segurança da informação para redes industriais, os seguintes pontos:

- **Analisar os riscos nas redes:** realizar uma série de atividades a fim de levantar os riscos envolvidos nas redes, bem como os itens que os cercam. Estas atividades podem/devem ser:
  - a) Inventário dos componentes da rede
  - b) Entrevistas com gestores e pessoas estratégicas na automação, principalmente os responsáveis pelas redes.
  - c) Análise das vulnerabilidades das redes industriais e corporativas
  - d) Avaliação e estimativa dos riscos e impactos no negócio
  - e) Definição de contrapartidas e planos de ação aos incidentes
  - f) Definição de atuação preventiva e gestão continuada de S.I.
- **Alinhar padrões com normas:** deve ser realizada uma análise constante do status das redes industriais, para assegurar que estejam em conformidade com as normas, principalmente quando ocorrem mudanças no cenário (redes) assim como quando ocorrem nas normas (revisões e desmembramentos de normas). Para tanto é necessário:
  - a) Manter o inventário dos componentes da rede atualizado
  - b) Avaliar os controles e políticas de S.I., bem como os níveis de seguridade dos mesmos.
  - c) Constante revisão dos planos e acompanhamento frequente das alterações das normas internacionais
  - d) Relatórios frequentes de conformidade dos itens do plano de ação e de continuidade, confrontando com as normas internacionais.
- **Analisar o ambiente operacional SCADA:** deve ser feita análise das vulnerabilidades no ambiente de operação SCADA, sendo principalmente averiguado o servidor e aplicativos que o compõem (Sistema Operacional,

aplicativos conjuntos, Banco de dados, regras e permissões de acesso). Neste item os pontos relevantes são:

a) Escaneamento constante e por ferramentas especificas e atualizadas do sistema operacional do servidor

b) Manter base de conhecimento das ações proativas de segurança, das varreduras efetuadas e dos resultados obtidos

c) Manter base de conhecimento seja por relatórios ou por banco de dados, das principais vulnerabilidades sofridas, bem como das medidas tomadas para remedia-las.

- **Dominar e dar suporte a segurança das redes industriais:** após todos os itens acimas assimilados, assumisse que a equipe técnica possui o domínio necessário da rede industrial e com isso transpassa o nível de segurança necessária para a mesma atuar em plenitude. Para certificar-se que há tal domínio e assim prestar os serviços que garantam o funcionamento, é preciso então que, no mímino, os seguintes pontos realmente sejam dominados:

a) Implementar procedimentos de governança para redes industriais
b) Implementar, revisar e controlar a politica de segurança de redes, bem como de controle de acessos
c) Conhecimento da localização física dos equipamentos (documentado)
d) Monitorar ambiente e sempre manter bases de testes e incidentes atualizadas
e) Deter conhecimento para resolução de problemas e/ou deter conhecimento de escalabilidade dos responsáveis pela resolução

5 DADOS COLETADOS JUNTO AOS USUÁRIOS DE REDES INDUSTRIAIS

Com intuito de levantar dados referentes ao mundo corporativo atual, foi pesquisado por meio de formulário eletrônico a colaboradores de diferentes áreas de atuação ligadas às redes industriais, sobre as redes industriais e as falhas de segurança da informação encontradas pelos mesmos no dia-a-dia.

A pesquisa inserida neste através do APÊNDICE A e divulgada aos entrevistados pelo website:

https://docs.google.com/spreadsheet/viewform?fromEmail=true&formkey=dDlwc01FY1luZlJWOGJ1NElBMmc3blE6MQ

Cita uma série de tipos de redes de comunicação, tipos de sistemas em uso e falhas de segurança afim de traçar um perfil das redes e seu status atual, do ponto de visto dos usuários.

Os resultados encontrados estão em APÊNDICE B e também foram apresentados de forma parcial ao término da pesquisa.

A compilação dos resultados mostra que

6 CONSIDERAÇÕES FINAIS

Com o advento da internet e das redes globais integrando pessoas, empresas, serviços entre outros, está cada vez mais imprescindível o cuidado com a segurança das informações, de seus equipamentos, de seus dados pessoais, enfim, de sua rede de dados. As indústrias não se isolam desta situação, sendo deveras importante que mantenham suas redes de comunicação em constante atualização e sob um olhar de segurança eficiente.

Nesse olhar, setores como TI e Automação devem estar engajadas para que as ferramentas, métricas e politicas sejam aplicadas e regidas com sucesso, pois o sucesso destes implica no sucesso da Indústria, assim como o insucesso poderá levar ao Fracasso da empresa.

Detalhes, ferramentas novas, culturas diversificadas, altos custos, ameaças internas e externas, falta de efetivo, falta de apoio gerencial entre outros, são os principais itens a serem considerados para a segurança das redes industriais, onde muitos deles são fatores que impedem o sucesso, mas que, se tratados com a devida importância assegura o sucesso também.

Com isso, pode-se concluir que na atualidade e em períodos futuros o fator segurança nas redes de comunicação industriais tem uma vital importância e deve ser tratada como tal, sendo desenhada/projetada por profissionais capacitados, utilizando ferramentas que comportem tal segurança, com politicas e métricas bem definidas, com usuários treinados, com o apoio gerencial e engajamento da alta direção, tudo para que haja rentabilidade das mesmas e alinhamento ao negocio, gerando então a satisfação do cliente interno e externo, evitando a proliferação de malwares diversos pelas redes, minimizando cada vez mais as inseguranças.

7 REFERÊNCIAS BIBLIOGRÁFICAS

Andraschko, F. R. & Sponholz, E., 2008. *ESTUDO DE APLICAÇÕES DISTRIBUÍDAS P2P.* Ponta Grossa - PR: s.n.

Araujo, F., 2011. *Os Protocolos de Rede.* [Online] Available at: http://www.inforlogia.com/os-protocolos-de-rede/ [Acesso em 05 Agosto 2012].

ARCNET Trade Association, 2002. *ARCNET Trade Association.* [Online] Available at: http://www.arcnet.com/ [Acesso em 15 Agosto 2012].

ARPANet, 2012. *Wikipedia ARPANet.* [Online] Available at: http://pt.wikipedia.org/wiki/ARPANET [Acesso em 05 Agosto 2012].

Bishop, M., 2002. *Computer Security: Art and Science.* s.l.:Addison-Wesley Professional.

Cantú, E., 2003. *Redes de Computadores e Internet.* São José: CEFET/SC.

CISCO, 2009. *Token Ring/IEEE 802.5.* [Online] Available at: http://docwiki.cisco.com/wiki/Token_Ring/IEEE_802.5 [Acesso em Agosto 2012].

Cogui, M. A., 2003. Critérios para seleção de redes para automação industrial. *Revista Mecatrônica Atual,* Setembro.Issue 11.

Comitê Gestor da Internet no Brasil, 2012. *Cartilha de Segurança para Internet, v. 4.0.* [Online] Available at: http://cartilha.cert.br [Acesso em setembro 2012].

DJIEV, S., 2003. *Industrial Networks for Communication and Control. Reading for Elements for Industrial Automation,* Sofia: Technical University.

International Committee on Taxonomy of Viruses, 2012. *International Committee on Taxonomy of Viruses.* [Online] Available at: http://www.ictvonline.org/ [Acesso em 2012].

International Organization for Standardization, 2005. *ISO/IEC 17799:2005.* [Online] Available at: http://www.iso.org/iso/catalogue_detail?csnumber=39612 [Acesso em 29 Agosto 2012].

Lugli, B. A., Santos, M. M. D. & Franco, L. R. H. R., 2009. Uma visão dos protocolos para redes Ethernet industriais e suas aplicações.

Martins, G. M., 2012. *Princípios de Automação Industrial.* Santa Maria - RS: UNIVERSIDADE FEDERAL DE SANTA MARIA.

Martins, G. M., 2012. *Princípios de Automação Industrial,* Santa Maria - RS: Universidade Federal de Santa Maria.

NIC BR Security Office, 2003. *Praticas de Segurança para Administradores de Redes Internet,* s.l.: s.n.

Norton Brasil, 2012. *Firewall e Antivírus - Norton Brasil.* [Online] Available at: http://br.norton.com/ [Acesso em 2012].

PARC, 2002. *PARC - A Xerox Company.* [Online] Available at: http://www.parc.com/ [Acesso em Agosto 2012].

Portal GeoBrasil, 2007. *Novo recorde marca início da popularização da Internet no Brasil: O número de usuários residenciais ativos atinge 16,3 milhões de brasileiros..* [Online]
Available at: http://www.portalgeobrasil.org/info/material/dadoswebbrasil.pdf [Acesso em Julho 2012].

Runge Filho, P. R., 2012. *Políticas de Segurança da Informação,* s.l.: s.n.

Souza, R., 2012. *CoooperaTI.* [Online] Available at: http://www.cooperati.com.br/wordpress/2012/08/02/camadas-modelo-osi-analogia-correios/
[Acesso em 05 Agosto 2012].

Tanenbaum, A. S., 2002. *Computer Networks.* 4 ed. s.l.:Prentice Hall.

The Internacional Society of Automation, 2012. *ISA.org.* [Online] Available at: http://www.isa.org [Acesso em Agosto 2012].

Torres, G., 2007. *O Modelo de Referencia OSI para Protocolos de Rede.* [Online] Available at: http://www.clubedohardware.com.br/artigos/O-Modelo-de-Referencia-

OSI-para-Protocolos-de-Rede/1349/4
[Acesso em 05 Agosto 2012].

APÊNDICE A – Questionário: Segurança de Redes de Comunicação para Sistemas de Automação Industrial

Website:
https://docs.google.com/spreadsheet/viewform?fromEmail=true&formkey=dDlwc01FY1luZlJWOGJ1NElBMmc3blE6MQ

Segurança em Redes de Comunicação para Sistemas de Automação Industrial

Essa pesquisa visa levantamento de informações sobre dificuldades, incidentes, práticas em uso e informações adicionais sobre Segurança em Redes de Comunicação para Sistemas de Automação Industrial. O resultado de tal questionário será aplicado ao meu projeto de Conclusão da Pós-Graduação em Segurança de Redes de Computadores.

* nenhuma informação sobre empresa, processo e ou identificação pessoal será coletada e compartilhada, apenas informações sobre experiências em ambientes industriais.

Obrigado pelo auxílio,

Francisco Ricardo

Page 2 | Após a página 1 | Ir para a página 2 (Dados para Verificação de Perfil)

Dados para Verificação de Perfil

Nesta seção serão respondidas questões sobre seu perfil pessoal, mas não será solicitada identificação como nome e outras.

Sexo *
Masculino

Idade *
Escolha a faixa etária referente a sua idade
menos de 15 anos

Estado Civil *
Solteiro (a)

Quantos Filhos? *
não tenho filhos

Qual o seu grau de instrução ? *
- Ensino Médio
- Ensino Técnico Profissionalizante
- Graduação
- Pós-graduação
- Outro:

Qual sua renda familiar bruta? *

não tenho renda fixa

Possui Computador Residencial? *

Sim

Se sim, Que tipo (desktop, notebook, netbook, ...)?

Tem Internet Residencial? *

Sim

Se sim, Que tipo (banda larda ADSL, via rádio, discada,...) ?

Acessa Internet de dispositivos móveis ? *

Sim

Se sim, Qual (celular, smartphone, tablet, ...) ?

Com que frequência acessa internet de 2a a 6a-feira (em casa e empresa) ? *

menos de 1 hora

Com que frequência acessa internet nos finais de semana (em casa e empresa) ? *

menos de 1 hora

Page 3 Após a página 2 Ir para a página 3 (Ramo de Atividade)

Ramo de Atividade

Nesta seção serão respondidas questões sobre: Ramo de Atividade, área e cargo de atuação e formação profissional

Qual ramo de atividade da empresa onde atua? *

Essa questão é para mensurar o ramo de atividade industrial que apresenta as menores ou maiores dificuldades.

Quantidade de Funcionários da Empresa *

até 100 colaboradores

Qual a sua área de atividade na empresa? *

Essa questão é para efetuar a divisão de áreas de atividade industrial que apresentam as menores ou maiores dificuldades.

- ◯ Administrativo
- ◯ Automação Industrial
- ◯ Manutenção Elétrica
- ◯ Manutenção Mecânica
- ◯ Tecnologia da Informação
- ◯ Outro:

Qual a sua atividade (cargo ou função) na empresa? *

Essa questão é para efetuar a divisão de funções que apresentam as menores ou maiores dificuldades.

Tempo de atividade na empresa *

menos de 1 ano

Tempo total de atividade *

menos de 1 ano

Page 4

Após a página 3

Ir para a página 4 (Conhecimentos Pessoais ...e Automação Industrial)

Conhecimentos Pessoais sobre: Redes de Computadores, Segurança da Informação e Automação Industrial

Nesta seção serão respondidas questões sobre seu conhecimento em Redes de Computadores, Segurança da Informação e Automação Industrial.

Qual o seu nível de conhecimento sobre redes de computadores? *

Tratar Redes de Computadores como: Cabeamento UTP, Conectorização de cabos, Padrões e Protocolos de Rede, Interligação em Redes de Computadores/Máquinas, ...

Nenhum

Possui algum curso específico em redes de computadores? *

Sim

Qual ?
Se possui curso, descreva qual (quais)

Qual o seu nível de conhecimento sobre Segurança da Informação? *
Tratar seu entendimento sobre Segurança da Informação e suas componentes.

Nenhum

Possui algum curso específico em Segurança da Informação? *

Sim

Qual ?
Se possui curso, descreva qual (quais)

Qual o seu nível de conhecimento sobre Automação Industrial? *
Tratar seu entendimento sobre Automação Industrial e suas componentes.

Nenhum

Possui algum curso específico em Automação Industrial? *

Sim

Qual ?
Se possui curso, descreva qual (quais)

Page 5 Após a página 4 Continuar para a próxima página

Ambiente de Rede e Falhas de Comunicação

Nessa seção serão respondidas questões sobre o Ambiente de Rede e as principais falhas e dificuldades de

comunicação encontradas

Quais os meios de comunicação usadas em sua rede? *

Pode ser marcada mais de uma opção (mín. 1)

- ☐ Token Ring (Cabeamento Coaxial)
- ☐ Ethernet (Cabeamento UTP) 10Mbit/s - 10BASE-T
- ☐ Ethernet (Fibra Optica) 10Mbit/s - 10BASE-F
- ☐ Fast Ethernet (Cabeamento UTP) 100Mbit/s - 100BASE-T
- ☐ Fast Ethernet (Fibra Optica) 100Mbit/s - 100BASE-FX
- ☐ Gigabit Ethernet (Cabeamento UTP) 1000Mbit/s - 1000BASE-T
- ☐ Gigabit Ethernet (Fibra Optica) 1000Mbit/s - 1000BASE-SX ou LX
- ☐ 10-Gigabit Ethernet (Cabeamento UTP) 10Gbit/s
- ☐ Wi-Fi (Wireless Fidelity - Sem fio convencional)
- ☐ Discada
- ☐ DSL (ADSL, ADSL Lite, ADSL2, ADSL2+, SDSL, IDSL, HDSL, RADSL, VDSL, VDSL2, G.SHDSL, VoDSL, PDSL, UDSL)
- ☐ Frame Relay / MPLS
- ☐ RDIS / ISDN / Conexão dedicada
- ☐ Rádio
- ☐ Satélite
- ☐ Rede Elétrica
- ☐ WiMax
- ☐ Mesh
- ☐ Ronja
- ☐ Bluetooth
- ☐ IrDA (Infravermelho)
- ☐ GSM
- ☐ CDMA
- ☐ TDMA
- ☐ 2G (GPRS)
- ☐ 2,5G (EDGE, 1xRTT)
- ☐ 3G (UMTS, HSPA, HSDPA, HSUPA, W-CDMA, EVDO)
- ☐ 4G (LTE ou outros)
- ☐ Outro: _____

Ao seu ver, em seu ambiente de trabalho existem problemas de comunicação na rede? *

- ○ Sim
- ○ Não

Page 6 Após a página 5 Ir para a página 7 (Segurança da Informação e Falhas)

Note: "Go to page" selections will override this navigation. Learn more.

Quais problemas de comunicação na rede, ocorrem com maior frequência? *

Pode selecionar mais de uma opção

- [ ] Queda na rede cabeada
- [ ] Queda na rede wireless
- [ ] Lentidão no acesso a Sistema
- [ ] Lentidão no acesso a Internet
- [ ] Lentidão no acesso a Intranet
- [ ] Lentidão na navegação do Sistema
- [ ] Lentidão na navegação a Internet
- [ ] Lentidão na navegação a Intranet
- [ ] Intermitência na rede local
- [ ] Falha na autenticação da rede
- [ ] Erro na autenticação do usuário de rede - Esquecimento de Senha
- [ ] Erro na autenticação do usuário de rede - Esquecimento de Usuário
- [ ] Outro:

Page 7 Após a página 6 Continuar para a próxima página

Segurança da Informação e Falhas

Nessa seção serão respondidas questões sobre o Ambiente de Segurança da Informação e possíveis falhas encontradas

Quais os tipos de segurança da informação são aplicados em seu ambiente de trabalho? *

Pode selecionar mais de uma opção

- [ ] Autenticação em Dominio (rede com usuário)
- [ ] Pastas com Senha
- [ ] Firewall Externo
- [ ] Firewall Interno
- [ ] Antivírus
- [ ] Antispam
- [ ] Spyware
- [ ] IDS / IPS
- [ ] Servidor de Arquivos
- [ ] Controle no arquivamento de documentos em servidor
- [ ] Servidor de Email
- [ ] Controle no envio de anexos no email

- [ ] Proxy de autenticação para Internet
- [ ] VPN
- [ ] Ambiente Metaframe
- [ ] Servidor de FTP
- [ ] Controle de Equipamentos Mobile
- [ ] Rede DMZ
- [ ] Antispoofing
- [ ] DDOS
- [ ] Politicas de Restrição de Acesso a Terceiros/Parceiros
- [ ] Rede Wifi Oculta - Acesso Interno
- [ ] Rede Wifi Para Terceiros
- [ ] Bloqueio de USB
- [ ] Restrição de Acesso Administrador no Computador
- [ ] Mudanças periódicas de senha
- [ ] Alto grau de dificuldade na geração de senhas
- [ ] Acesso Restrito (controlado) a Ambientes
- [ ] Bloqueio de Download
- [ ] Bloqueio de Upload
- [ ] Bloqueio a sites
- [ ] Backup em Fita ou outra mídia externa
- [ ] Backup em Disco ou outra mídia interna
- [ ] Backup em Nuvem ou ambiente remoto
- [ ] Ambiente controlado para Fitas de Backup (cofre ou outros)
- [ ] Níveis de aprovação de documentos e de liberações
- [ ] Câmeras de Monitoramento Interno ou Externo
- [ ] Controle nas ligações telefônicas (monitoramento ou senha)
- [ ] Bloqueio nas Ligações de Celular (DDD, DDI, ou Local)
- [ ] Bloqueio no envio de Mensagens de Celular (SMS, MMS)
- [ ] Digitalização de Documentos Impressos
- [ ] Arquivamento de Documentos Impressos em local seguro
- [ ] Outro: _____

Quais falhas de segurança, ocorrem com maior frequência em seu ambiente de trabalho? *

Pode selecionar mais de uma opção

- [ ] Infecção de Vírus
- [ ] Infecção de Spyware
- [ ] Infecção de Trojans
- [ ] Infecção de Spam
- [ ] Infecção de Malwares

- [ ] Intrusão Hacker
- [ ] Intrusão Cracker
- [ ] Intrusão Phreaker
- [ ] Roubo de Informações por Funcionários ou Ex-Funcionários (ataques internos)
- [ ] Exclusão indevida de conteúdo
- [ ] Distribuição indevida de conteúdo
- [ ] Tentativa de uso de conta/senha alheia
- [ ] Troca de senha alheia
- [ ] Acesso indevido de Internet Corporativa
- [ ] Uso indevido de Email Corporativo
- [ ] Uso indevido de Email Particular em ambiente Corporativo
- [ ] Uso de email alheio
- [ ] Uso indevido de email alheio
- [ ] Uso de equipamento corporativo para fins pessoais
- [ ] Uso de recursos corporativos para fins pessoais
- [ ] Uso de equipamentos pessoais em ambiente corporativo
- [ ] Uso de recursos pessoais em ambiente corporativo
- [ ] Uso não autorizado de softwares licenciados
- [ ] Uso de softwares não licenciados (piratas)
- [ ] Não existencia de backup
- [ ] Perda das Midias de Backup
- [ ] Danos propositais a equipamentos e recursos corporativos
- [ ] Acesso não autorizado de pessoas a locais restritos
- [ ] Acesso indevido de pessoas a locais críticos (mas não restritos)
- [ ] Outro:

Page 8 — Após a página 7 — Continuar para a próxima página

Comentários Gerais

Campo aberto e não obrigatório para comentários gerais sobre Redes e/ou Segurança da Informação.

Page 9 — Após a página 8 — Continuar para a próxima página

Conclusão da Pesquisa

Muito Obrigado pelo Auxilio,

O investimento do seu tempo nesta pesquisa foi muito útil para o discorrer de meu trabalho e futuros.

Francisco Ricardo
fricardo.it@gmail.com

APÊNDICE B – Resultados do Questionário: Segurança de Redes de Comunicação para Sistemas de Automação Industrial

Website:
https://docs.google.com/spreadsheet/viewform?fromEmail=true&formkey=dDlwc01FY1luZlJWOGJ1NElBMmc3blE6MQ

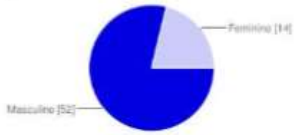
66 responses

Resumo

Dados para Verificação de Perfil

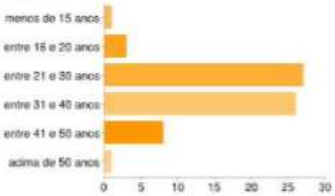
Nesta seção serão respondidas questões sobre seu perfil pessoal, mas não será solicitada identificação como nome e outras.

Sexo



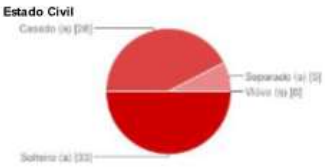
Masculino	52	79%
Feminino	14	21%

Idade



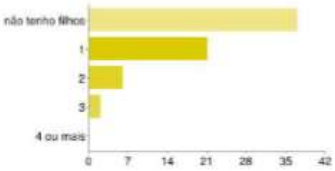
menos de 15 anos	1	2%
entre 16 e 20 anos	3	5%
entre 21 e 30 anos	27	41%
entre 31 e 40 anos	26	39%
entre 41 e 50 anos	8	12%
acima de 50 anos	1	2%

Estado Civil



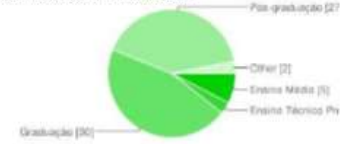
Solteiro (a)	33	50%
Casado (a)	28	42%
Separado (a)	5	8%
Viúvo (a)	0	0%

Quantos Filhos?



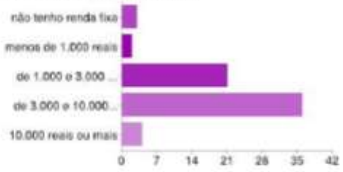
não tenho filhos	37	56%
1	21	32%
2	6	9%
3	2	3%
4 ou mais	0	0%

Qual o seu grau de instrução ?



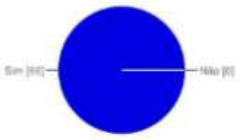
Ensino Médio	5	8%
Ensino Técnico Profissionalizante	2	3%
Graduação	30	45%
Pós-graduação	27	41%
Other	2	3%

Qual sua renda familiar bruta?



não tenho renda fixa	3	5%
menos de 1.000 reais	2	3%
de 1.000 e 3.000 reais	21	32%
de 3.000 e 10.000 reais	36	55%
10.000 reais ou mais	4	6%

Possui Computador Residencial?



Sim	66	100%
Não	0	0%

Se sim, Que tipo (desktop, notebook, netbook, ...)?

notebook desktop, notebook Desktop e notebook ambos note e desktop desktop notebook notebook desktop e notebook notebook desktop notebook notebook Net Um Desktop e um notebook. notebook, desktop desktop Notebook, De ...

Tem Internet Residencial?

Sim	62	94%
Não	4	6%

Se sim, Que tipo (banda larda ADSL, via rádio, discada,...) ?

adsl ADSL banda larga adsl 10mb via rádio via rádio banda larga net Virtua banda larga AdSL Banda Larga Adsl ADSL ADLS adsl ADSL banda larga adsl ADSL Placa de dados VIVO ADSL+ 2 ADSL Banda Larga ADSL Banda Larga ADSL ban ...

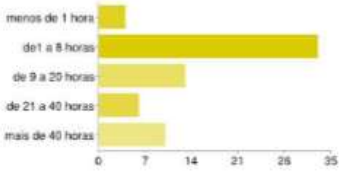
Acessa Internet de dispositivos móveis ?

Sim	51	77%
Não	15	23%

Se sim, Qual (celular, smartphone, tablet, ...) ?

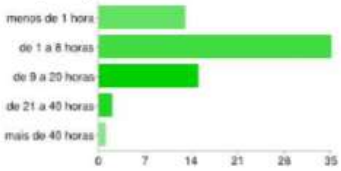
smartphone smartphone Smartphone celular smartphone celular celular e tablet smartphone e tablet smartphone celular Smartphone Atrix Smartphone smartphone Tablet celular Galaxy || Celular Smartphone smartphone celular ...

Com que frequência acessa internet de 2a a 6a-feira (em casa e empresa) ?



menos de 1 hora	4	6%
de1 a 8 horas	33	50%
de 9 a 20 horas	13	20%
de 21 a 40 horas	6	9%
mais de 40 horas	10	15%

Com que frequência acessa internet nos finais de semana (em casa e empresa) ?



menos de 1 hora	13	20%
de 1 a 8 horas	35	53%
de 9 a 20 horas	15	23%
de 21 a 40 horas	2	3%
mais de 40 horas	1	2%

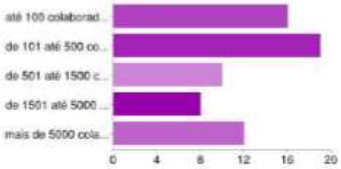
Ramo de Atividade

Nesta seção serão respondidas questões sobre: Ramo de Atividade, área e cargo de atuação e formação profissional

Qual ramo de atividade da empresa onde atua?

Negócios imobiliaria Serviços Tecnologicos Telecomunicações bancario consórcio universidade Confecção financeiro Serviços Prestação de Serviços Textil Textil Telecomunicaçao Comercial CONSORCIOS Comércio Textil educa ...

Quantidade de Funcionários da Empresa



até 100 colaboradores	16	24%
de 101 até 500 colaboradores	19	29%
de 501 até 1500 colaboradores	10	15%
de 1501 até 5000 colaboradores	8	12%
mais de 5000 colaboradores	12	18%

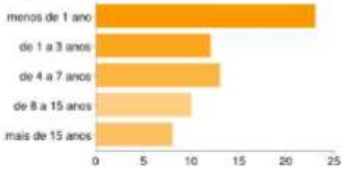
Qual a sua área de atividade na empresa?

Administrativo	14	21%
Automação Industrial	4	6%
Manutenção Elétrica	1	2%
Manutenção Mecânica	1	2%
Tecnologia da Informação	33	50%
Other	13	20%

Qual a sua atividade (cargo ou função) na empresa?

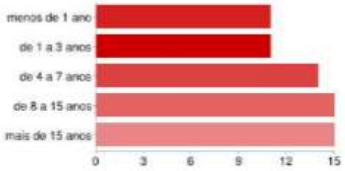
Analista de TI Atendiment a usuarios Analista de TI Recrutamento e Seleção trainee Analista chefe de departamento aux. adm analista de negócios Analista TI Analista de Tec da Informação Analista de Suporte Coor ...

Tempo de atividade na empresa



menos de 1 ano	23	35%
de 1 a 3 anos	12	18%
de 4 a 7 anos	13	20%
de 8 a 15 anos	10	15%
mais de 15 anos	8	12%

Tempo total de atividade

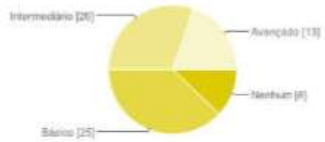


menos de 1 ano	11	17%
de 1 a 3 anos	11	17%
de 4 a 7 anos	14	21%
de 8 a 15 anos	15	23%
mais de 15 anos	15	23%

Conhecimentos Pessoais sobre: Redes de Computadores, Segurança da Informação e Automação Industrial

Nesta seção serão respondidas questões sobre seu conhecimento em Redes de Computadores, Segurança da Informação e Automação Industrial.

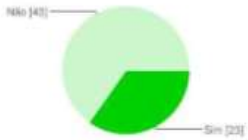
Qual o seu nível de conhecimento sobre redes de computadores?



Nenhum	8	12%
Básico	25	38%
Intermediário	20	30%
Avançado	13	20%

Possui algum curso específico em redes de computadores?

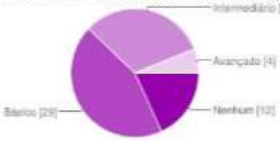
Sim	23	35%
Não	43	65%



Qual ?

MCTS Windows Server 2008 - Infraestrutura de Redes Graduação Ciencia da Computacao e curso técnico em informatica. pos graduacao, certificacao server 2008, firewalls, dentre outros TCP/IP/CCNA/SNA/Redes Corporativas/wifi/Cabling Adm de redes Data cabling system Furukawa e CCNA. Curso de Redes de Microsoft Microsoft CCNA Furukawa Gerenciamento de Rede de Computadores. Redes de Computadores Básico Pós graduação em redes de computadores TCP/IP - INFRA ESTRUTURA Cisco Network Academy Manutenção em micro computadores e redes furukawa certificado professional - fundamental Pós em Rede de computadores Redes de co ...

Qual o seu nível de conhecimento sobre Segurança da Informação?



Nenhum	12	18%
Básico	29	44%
Intermediário	21	32%
Avançado	4	6%

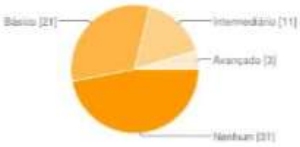
Possui algum curso específico em Segurança da Informação?

Sim	10	15%
Não	56	85%

Qual ?

MCTS Windows Server 2008 - Diretório de Ativos seg. corporativa Fortinet Pós-graduação em Segurança da Informação Pentesting SQLMap Penetretion Pythons for Hackers and Reverse Engineeries curso não, apenas aprendi o básico na aula de informática. Modulo Security Office

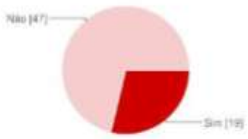
Qual o seu nível de conhecimento sobre Automação Industrial?



Nenhum	31	47%
Básico	21	32%
Intermediário	11	17%
Avançado	3	5%

Possui algum curso específico em Automação Industrial?

Sim	19	29%
Não	47	71%



Qual ?

Tecnico em Eletronica Faculdade de Engenharia da Computação Arduino with XBee PIC-18 Tecnologia em Automação Técnico em instrumentação Tecnologo em Automação, Eletrotecnico e Eletronico industrial Curso Tecnologia de Processos de Fabricação (disciplinção de Automação) Protocolos de automação Foundation Fieldbus, Profibus, Modbus, OPC Tecnólogo de Automação Industrial, MBA de Automação Industrial Curso SENAI de automação industrial

Ambiente de Rede e Falhas de Comunicação

Nessa seção serão respondidas questões sobre o Ambiente de Rede e as principais falhas e dificuldades de comunicação encontradas

Quais os meios de comunicação usadas em sua rede?

Token Ring (Cabeamento Coaxial)
Ethernet (Cabeamento UTP) 10Mbit/s - 10BASE-T
Ethernet (Fibra Optica) 10Mbit/s - 10BASE-F
Fast Ethernet (Cabeamento UTP) 100Mbit/s - 100BASE-T
Fast Ethernet (Fibra Optica) 100Mbit/s - 100BASE-FX
Gigabit Ethernet (Cabeamento UTP) 1000Mbit/s - 1000BASE-T
Gigabit Ethernet (Fibra Optica) 1000Mbit/s - 1000BASE-SX ou LX
10-Gigabit Ethernet (Cabeamento UTP) 10Gbit/s
Wi-Fi (Wireless Fidelity - Sem fio convencional)
Discada
DSL (ADSL, ADSL Lite, ADSL2, ADSL2+, SDSL, IDSL, HDSL, RADSL, VDSL, VDSL2, G.SHDSL, VoDSL, F
Frame Relay / MPLS
RDIS / ISDN / Conexão dedicada
Rádio
Satélite
Rede Elétrica
WiMax
Mesh
Ronja
Bluetooth
IrDA (Infravermelho)
GSM
CDMA
TDMA
2G (GPRS)
2,5G (EDGE, 1xRTT)
3G (UMTS, HSPA, HSDPA, HSUPA, W-CDMA, EVDO)
4G (LTE ou outros)
Other

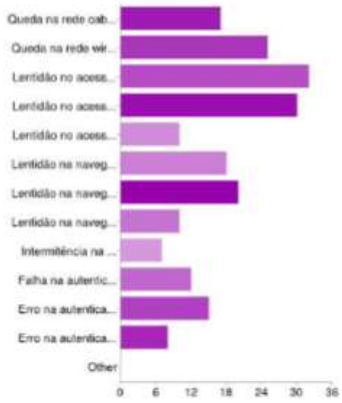
People may select more than one checkbox, so percentages may add up to more than 100%.

Ao seu ver, em seu ambiente de trabalho existem problemas de comunicação na rede?

Sim	**44**	67%
Não	**22**	33%

Quais problemas de comunicação na rede, ocorrem com maior frequência?

Queda na rede cabeada	**17**	39%
Queda na rede wireless	**25**	57%
Lentidão no acesso a Sistema	**32**	73%
Lentidão no acesso a Internet	**30**	68%
Lentidão no acesso a Intranet	**10**	23%
Lentidão na navegação do Sistema	**18**	41%



Lentidão na navegação a Internet	20	45%
Lentidão na navegação a Intranet	10	23%
Intermitência na rede local	7	16%
Falha na autenticação da rede	12	27%
Erro na autenticação do usuário de rede - Esquecimento de Senha	15	34%
Erro na autenticação do usuário de rede - Esquecimento de Usuário	8	18%
Other	0	0%

People may select more than one checkbox, so percentages may add up to more than 100%.

Segurança da Informação e Falhas

Nessa seção serão respondidas questões sobre o Ambiente de Segurança da Informação e possíveis falhas encontradas

Quais os tipos de segurança da informação são aplicados em seu ambiente de trabalho?

Autenticação em Dominio (rede com usuário)	54	82%
Pastas com Senha	22	33%
Firewall Externo	33	50%
Firewall Interno	36	55%
Antivírus	64	97%
Antispam	47	71%
Spyware	28	42%
IDS / IPS	11	17%
Servidor de Arquivos	46	70%
Controle no arquivamento de documentos em servidor	26	39%
Servidor de Email	48	73%
Controle no envio de anexos no email	28	42%
Proxy de autenticação para Internet	32	48%
VPN	33	50%
Ambiente Metaframe	14	21%
Servidor de FTP	24	36%
Controle de Equipamentos Mobile	6	9%
Rede DMZ	13	20%
Antispoofing	6	9%
DDOS	4	6%
Politicas de Restrição de Acesso a Terceiros/Parceiros	26	39%
Rede Wifi Oculta - Acesso Interno	33	50%
Rede Wifi Para Terceiros	22	33%
Bloqueio de USB	11	17%
Restrição de Acesso Administrador no Computador	31	47%
Mudanças periódicas de senha	29	44%
Alto grau de dificuldade na geração de senhas	13	20%
Acesso Restrito (controlado) a Ambientes	26	39%
Bloqueio de Download	35	53%
Bloqueio de Upload	26	39%
Bloqueio a sites	43	65%
Backup em Fita ou outra mídia externa	24	36%
Backup em Disco ou outra mídia interna	25	38%
Backup em Nuvem ou ambiente remoto	5	8%
Ambiente controlado para Fitas de Backup (cofre ou outros)	16	24%
Níveis de aprovação de documentos e de liberações	15	23%
Câmeras de Monitoramento Interno ou Externo	30	45%

Controle nas ligações telefônicas (monitoramento ou senha)	**25**	38%
Bloqueio nas Ligações de Celular (DDD, DDI, ou Local)	**18**	27%
Bloqueio no envio de Mensagens de Celular (SMS, MMS)	**9**	14%
Digitalização de Documentos Impressos	**15**	23%
Arquivamento de Documentos Impressos em local seguro	**16**	24%
Other	**1**	2%

People may select more than one checkbox, so percentages may add up to more than 100%.

Quais falhas de segurança, ocorrem com maior frequência em seu ambiente de trabalho?

Infecção de Virus	**41**	62%
Infecção de Spyware	**15**	23%
Infecção de Trojans	**17**	26%
Infecção de Spam	**22**	33%
Infecção de Malwares	**11**	17%
Intrusão Hacker	**3**	5%
Intrusão Cracker	**3**	5%
Intrusão Phreaker	**1**	2%
Roubo de Informações por Funcionários ou Ex-Funcionários (ataques internos)	**5**	8%
Exclusão indevida de conteúdo	**21**	32%
Distribuição indevida de conteúdo	**8**	12%
Tentativa de uso de conta/senha alheia	**17**	26%
Troca de senha alheia	**4**	6%
Acesso indevido de Internet Corporativa	**18**	27%
Uso indevido de Email Corporativo	**26**	39%
Uso indevido de Email Particular em ambiente Corporativo	**19**	29%

Uso de email alheio	5	8%
Uso indevido de email alheio	2	3%
Uso de equipamento corporativo para fins pessoais	28	42%
Uso de recursos corporativos para fins pessoais	21	32%
Uso de equipamentos pessoais em ambiente corporativo	22	33%
Uso de recursos pessoais em ambiente corporativo	16	24%
Uso não autorizado de softwares licenciados	10	15%
Uso de softwares não licenciados (piratas)	20	30%
Não existencia de backup	9	14%
Perda das Mídias de Backup	9	14%
Danos propositais a equipamentos e recursos corporativos	6	9%
Acesso não autorizado de pessoas a locais restritos	14	21%
Acesso indevido de pessoas a locais críticos (mas não restritos)	10	15%
Other	0	0%

People may select more than one checkbox, so percentages may add up to more than 100%.

Comentários Gerais

Campo aberto e não obrigatório para comentários gerais sobre Redes e/ou Segurança da Informação.

Bos pesquisa, com grande gama de opções nas áreas envolvidas, da tecnologia e que as empresas possam usufruir e deixar os colaboradores ter acesso. Pelo porte da empresa os sistemas e segurança é falho.

Espero avanço sempre
Empresa em fase de restruturação em seu ambiente de TI.

Conclusão da Pesquisa

Muito Obrigado pelo Auxilio, O investimento do seu tempo nesta pesquisa foi muito útil para o discorrer de meu trabalho e futuros. Francisco Ricardo fricardo.it@gmail.com